ZIRLANDIA MILKOVIC

YOUR DATA IS THE TARGET

The Small Business Playbook for AI Privacy, GDPR and Digital Risk



PROTECT YOUR BUSINESS.
BUILD TRUST. STAY AHEAD.

GDPRGard

THE SMALL BUSINESS PLAYBOOK

YOUR DATA IS THE TARGET

The Small Business Playbook for AI Privacy, GDPR and Digital Risk

ZIRLANDIA MILKOVIC

PROTECT YOUR BUSINESS · BUILD TRUST · STAY AHEAD

Your Data Is the Target

The Small Business Playbook for AI Privacy, GDPR and Digital Risk

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced, stored or transmitted in any form without written permission, except for brief quotations in reviews and for copying the checklists, templates and policy text for your own business use.

EDUCATIONAL USE ONLY. This book is a general educational guide to data protection, cybersecurity and AI risk for small businesses in Europe. It is not legal advice, not a professional cybersecurity service and not a compliance assessment. It does not create a lawyer-client or consultant-client relationship, it cannot take your individual circumstances into account, and the author is not presented as a lawyer, a certified data protection officer or a regulator. Reading this book, using its templates or completing its checklists does not make a business compliant with the GDPR or any other law, is not a certification or audit, and does not prevent cyberattacks or guarantee any outcome in an investigation, complaint, claim or incident.

THE LAW MOVES. Legal research for this edition closed on 24 October 2026. Data protection, cybersecurity and AI law, regulator guidance, court decisions and provider terms change often, and national rules differ between countries. Check the sources listed in Appendix M and the Sources section, and take advice from a qualified professional before relying on anything here for a decision with real consequences.

Product and company names belong to their owners and are used only for identification and education. This independent book is not affiliated with, sponsored or endorsed by any of them. The DATA SHIELD METHOD is an original practical framework created for this book. It is not an official regulatory standard.

All people, businesses and incidents in the scenarios and case studies are hypothetical, invented to illustrate ideas. They are not real enforcement cases.

Kindle Edition 2026 · Legal research cut-off: 24 October 2026

Contents

Info Educational and Legal Disclaimer 6
Bio A Note From the Author 7
Intro Your Data Is More Valuable Than You Think 8
Use How to Use This Book and the DATA SHIELD METHOD 11
60' Protect Your Business in Your First 60 Minutes 15

PART I **Understanding the Threat**

01 Your Data Is the Target 19
02 The Hidden Cost of a Digital Mistake 25
03 Your Digital Attack Surface 30
04 The Human Factor 36

PART II **AI Privacy: The New Business Risk**

05 Before You Paste It Into AI 42
06 Using AI Without Exposing Your Business 49
07 AI Vendors, Data Processing and Your Responsibilities 54
08 Deepfakes, AI Fraud and Business Impersonation 59

PART III **GDPR Without the Confusion**

09 What GDPR Actually Requires From Your Business 65
10 Know What You Collect and Why 72
11 Privacy Policies, Cookies and Customer Rights 79
12 Processors, Suppliers and International Data Transfers 85
13 DPIAs, Privacy by Design and Accountability 91

PART IV **Building Your Digital Defense**

14 A Cybersecurity Baseline for Small Businesses 97
15 Vendor and Supply-Chain Risk 103
16 Your First 72 Hours After a Data Breach 108
17 Business Continuity and Recovery 117

PART V **Your Practical Protection Toolkit**

18 The Small Business Privacy and Security Audit 123
19 Your 30-Day Digital Risk Reduction Plan 131
20 Turning Compliance Into Customer Trust 139

End You Are Not Too Small to Matter, and Not Too Small to Protect 144
End Your Final Practical Checklist 146

APPENDICES: TEMPLATES AND TOOLS

A Small Business GDPR Checklist 147
B Responsible AI Use Policy Template 148
C AI Tool Approval Checklist 149
D Data Inventory and Record of Processing Starter 150
E Vendor and AI Supplier Assessment Questionnaire 151
F Data Breach Incident Log 153
G Personal Data Breach Response Checklist 153
H Employee Security Awareness Checklist 154
I Data Retention Schedule Template 155
J Privacy and Security Risk Register 156
K Monthly Security Review Checklist 157
L Glossary of Terms 158
M Official Sources and Further Reading 160
Ref Sources 161
Bio About the Author 165

Educational and Legal Disclaimer

Please read this page before you use anything else in the book.

This book is an educational publication. It explains, in plain English, how data protection law, cybersecurity practice and artificial intelligence (AI) risk fit together for small businesses in Europe. It is **not legal advice**, it is not a professional cybersecurity service, and it is not a formal compliance assessment. It cannot take account of the facts of your business.

The author is not presented as a lawyer, a certified data protection officer (DPO) or a regulator. Nothing here is endorsed or approved by any supervisory authority, the European Commission, the European Data Protection Board (EDPB), ENISA or any technology provider. Completing a checklist, adopting a template or following the DATA SHIELD METHOD does **not** make a business compliant with the General Data Protection Regulation (GDPR) or any other law, and it does not prevent cyberattacks or guarantee any outcome in an incident, complaint or investigation.

Three things can change after publication:

- **The law and its dates.** Legal research for this edition closed on **24 October 2026**. The EU AI Act was amended in July 2026. Changes to the GDPR proposed in the EU's "Digital Omnibus" package had, as far as the research found, not been adopted at that date. Appendix M and the Sources section list what to re-check.
- **Guidance and provider terms.** Regulators update their guidance and technology providers change their terms, often without notice. Always read the current terms of the specific service you use.
- **National rules.** The GDPR applies across the EU and the European Economic Area (EEA), but national laws on employment, health, cookies, children's data and breach reporting differ, and every supervisory authority publishes its own guidance.

The book is written for small organisations that operate in the EU or EEA. Where something applies only in the United Kingdom, the text says so. Where it says "the GDPR" without qualification, it means Regulation (EU) 2016/679.

Every case study and scenario is **hypothetical**, and labelled as such. No real incident, penalty, statistic or quotation has been invented. Where the book relies on a source, it gives a number in square brackets, such as [1], that points to the Sources section at the end. The final column of that section says how each source was checked, so that you can tell what still needs verification.

> WATCH OUT **When to get professional help**
>
> Take specialist advice before you rely on this book for a decision about special-category data, children's data, employee monitoring, automated decisions about people, large-scale profiling, transfers of data outside Europe, a suspected personal data breach that may put people at risk, or a significant contract with a technology supplier.

A Note From the Author

Why this guide exists, and what it is meant to do for you.

I wrote this book for the person who runs a business and also happens to be the person who answers the privacy emails, resets the passwords and wonders whether the new software is safe. Most of the guidance available to them is written either for lawyers or for large companies with security teams. Neither is much use at five o'clock on a Thursday.

My aim is to make data protection and responsible AI practice **understandable and actionable** for small businesses. That means plain language, honest limits and a lot of practical steps. It also means admitting what I cannot promise. No book can make you secure, and no checklist can make you lawful. What a good guide can do is help you see your risks clearly, spend your limited time on the things that matter most, and build habits that make a mistake less likely and less costly.

You will meet the **DATA SHIELD METHOD** in the pages that follow. It is a framework I developed for this book to keep the many moving parts in one picture. It is not an official standard, and it does not replace the legal texts or the guidance of your national supervisory authority. Its job is to give you an order in which to work.

Everything in this book is meant to be useful without buying anything else, and every template can be adapted and reused in your own business.

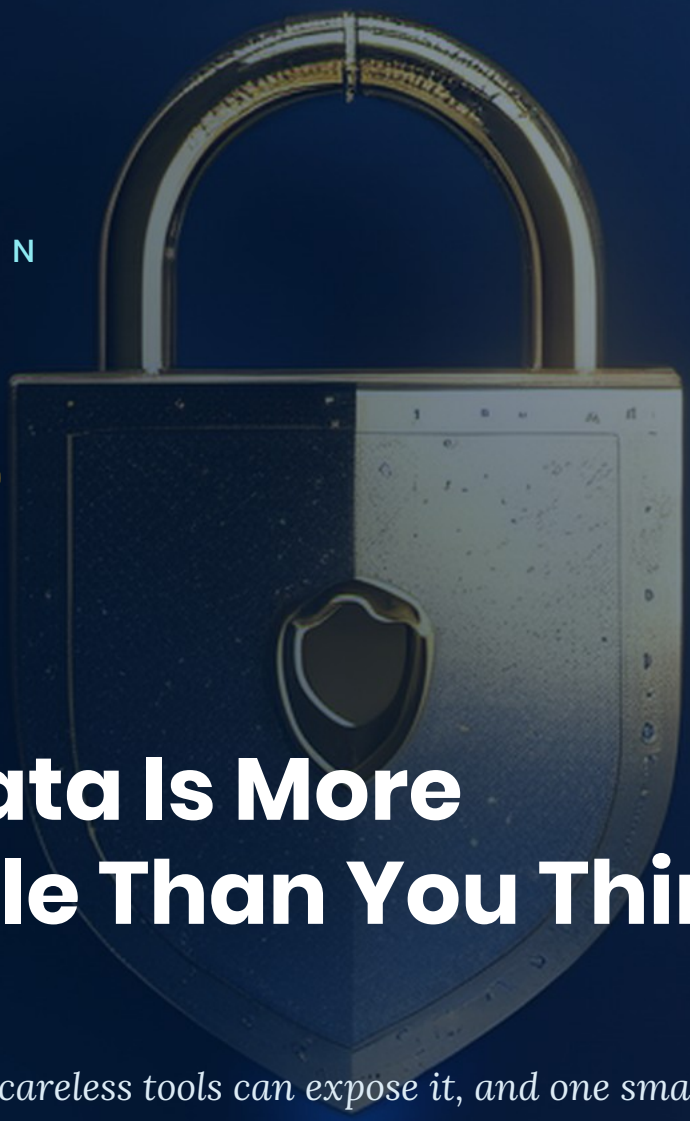
If you take one thing from these pages, let it be this: **you are not too small to matter, and you are not too small to protect what matters.**

Zirlandia Milkovic

INTRODUCTION

INTRODUCTION

DS



Your Data Is More Valuable Than You Think

Criminals want it, careless tools can expose it, and one small mistake can become a business crisis.

IN THIS CHAPTER

- Why the data in an ordinary small business is valuable to other people
- Why "we are too small to be targeted" is a dangerous assumption
- The risks this book covers, and how it is organised
- What it does not promise

HYPOTHETICAL EXAMPLE **A hypothetical Tuesday**

Nika runs a six-person online shop that sells handmade ceramics. On a quiet Tuesday she receives a message that appears to come from her payment provider: "Unusual activity on your account. Confirm your login within 30 minutes to avoid suspension." The page looks right. She types her password. Nothing seems to happen. That afternoon her assistant pastes a spreadsheet of customer complaints into a free AI tool to "find the common themes". The sheet contains names, addresses and phone numbers. By evening a supplier emails to say the bank details on their latest invoice have changed. Nika's bookkeeper, in a hurry, updates them. No alarms go off and no one is hacked in a way anyone would notice. Yet by the end of the week the shop has a compromised payment account, a customer list in a tool nobody approved, and money sent to the wrong place.

Nothing in that story is exotic. It is a phishing message, an unreviewed AI tool and an invoice fraud, all in a day. It is also **hypothetical**, and the book does not claim that any of these things is inevitable. It shows how ordinary the starting points are.

What makes small-business data valuable

A small business holds more than most owners realise: customer names, addresses and order histories; employee contracts and bank details; supplier terms and invoices; passwords and access to payment platforms; marketing lists; and a stock of know-how that took years to build. To someone else, each of these has a use. Customer data can be used for fraud. Access to your email can be used to impersonate you. Your invoices can be copied to redirect a payment. Your reputation can be damaged by a leak even when no one meant any harm.

Why "we are too small" is dangerous

Many attacks are not aimed at you personally. They are sent to thousands of addresses at once, and they succeed wherever someone clicks. Small organisations are not exempt from this, and they often have fewer defences and no one whose job is security. ENISA, the EU Agency for Cybersecurity, has published guidance specifically for small and medium-sized enterprises (SMEs) because their circumstances differ from those of large firms [16]. The right conclusion is not alarm. It is proportion: **you do not need enterprise-grade defences, but you do need to cover the basics.**

The risks this book covers



Figure 1 Four families of risk, one connected picture

What this book promises, and what it does not

It promises practical, plain-English guidance, drawn from official sources where it makes legal or technical claims, and organised around a single method. It promises honesty: where a point is a legal requirement, it says so; where it is a recommendation, it says that instead.

It does not promise that you will be perfectly secure or fully compliant. It does not use fear in place of evidence, and it does not quote statistics it cannot source. A calm, steady approach protects a business better than panic does.

THE IDEA BEHIND EVERY CHAPTER

Protection is not one big project. It is a handful of sensible habits, repeated: know what you have, decide what matters, tighten what is loose, write it down, and be ready for the day something goes wrong.

HOW TO USE THIS BOOK

GUIDE

DS

How to Use This Book and the DATA SHIELD METHOD

A way to read the book, and the framework that ties it together.

IN THIS CHAPTER

- How the five parts and 20 chapters are organised
- The ten steps of the DATA SHIELD METHOD
- What each chapter contains
- How to read the book in an hour, a week or a month

You can read this book from start to finish, but you do not have to. The structure lets you go straight to what you need.

The structure at a glance

Five parts, one journey

Part	What it does	Chapters
I. Understanding the Threat	Shows what is at risk, what mistakes cost and where your exposure is.	1 to 4
II. AI Privacy	Explains the new risks from AI tools and how to use them safely.	5 to 8
III. GDPR Without the Confusion	Sets out what the law requires and how to organise it.	9 to 13
IV. Building Your Digital Defense	Covers security basics, suppliers, breach response and continuity.	14 to 17
V. Your Practical Protection Toolkit	Gives you an audit, a 30-day plan and a way to turn compliance into trust.	18 to 20

The DATA SHIELD METHOD

The **DATA SHIELD METHOD** is an original practical framework developed for this book. It is **not** an official regulatory standard and it does not appear in any law or guidance. Its purpose is to give a small business an order of work. Each letter is a step, and the steps form a loop, because protection is never finished.

01
D · Discover
Identify the data, systems, vendors and AI tools your business actually has.

02
A · Assess
Evaluate privacy, security and operational risks in proportion to what could go wrong.

03
T · Tighten
Put proportionate controls and safer workflows in place.

04
A · Account
Document decisions, responsibilities and the measures you have taken.

05
S · Safeguard
Protect accounts, systems, data and people.

06
H · Handle
Prepare for incidents and for requests from individuals.

07
I · Improve
Train staff, test controls and review risks.

08
E · Evidence
Keep records that show what you decided and why.

09
L · Learn
Review incidents, changes and new threats, and adjust.

10
D · Defend
Make protection an ongoing business practice, not a one-off project.

Figure 2 The DATA SHIELD METHOD: ten steps, used throughout the book

Every chapter opens with a short **DATA SHIELD** note that says which steps it supports. You do not need to memorise the letters. They are a map, and the chapters do the walking.

What each chapter contains

Each chapter follows the same pattern, so you always know where to find things:

1. **An opening scenario.** A realistic, hypothetical situation that shows the problem.
2. **Why it matters.** The risk in plain English, and the legal or technical background where it applies.
3. **A case study.** A hypothetical small business, with its mistake and its fix.
4. **Common mistakes and misconceptions.** What people get wrong, and what is true instead.

5 **Step-by-step actions.** What to do, in order.
6 **A checklist.** A short list to tick.
7 **What to do today.** One action you can finish before the day ends.
8 **Summary and sources.** The key points, and numbered references.

Reading it your way

Three ways to use the book

If you have...	Do this
One hour	Skip to the quick-start checklist on the next pages, then read Chapters 5, 8 and 16.
One week	Read Part I and Part IV, then complete the audit in Chapter 18.
One month	Follow the 30-day plan in Chapter 19, reading each chapter as the plan reaches it.

SOURCE NOTE **Law, guidance and good practice**

This book separates four kinds of statement. **Binding law** is what legislation requires. **Regulatory guidance** is what regulators say about how they read it. **Voluntary standards and frameworks**, such as those from NIST or ISO, are good practice and not obligations. **The author's practical suggestions** are marked as such. The callouts "What the law says" and "Good practice" appear where the difference matters.

QUICK-START CHECKLIST

START

60

Protect Your Business in Your First 60 Minutes

Ten small actions that close the most common gaps before you read another page.

IN THIS CHAPTER

- Ten actions that fit into one hour
- Which of them protect against which risks

You can reduce your exposure noticeably in an hour. These actions do not make you secure or compliant. They close doors that are very commonly left open. Do them in order and tick them off.

0 to 10 min

Turn on multifactor authentication

Enable it (a second proof of identity, such as an app code) on your email, bank, payment provider and cloud storage. Start with email: it can reset everything else.

10 to 20 min

Check your email forwarding

Look in your email settings for automatic forwarding rules you did not create. Attackers use them to watch your mail.

20 to 30 min

List your accounts

Write down the ten systems that hold customer, employee or payment data, and who can log in to each.

30 to 40 min

Remove old access

Delete accounts for former staff, freelancers and tools no longer used. Remove shared passwords where you can.

40 to 45 min

Ask about AI tools

Ask each person which AI tools they use for work. Say clearly that honest answers will not be punished.

45 to 50 min

Set one AI rule

Tell the team: no customer personal data, passwords or confidential contracts in any AI tool that the business has not approved.

50 to 55 min

Agree a payment check

Any new or changed bank details must be confirmed by a phone call to a number you already hold.

55 to 60 min

Check one backup

Find where your most important files are backed up, and confirm that you could actually open one.

Figure 3 Your first 60 minutes

QUICK-START CHECKLIST

- [ ] Multifactor authentication is switched on for email, banking, payments and cloud storage.
- [ ] I have checked for unknown email forwarding rules.
- [ ] I have written down the ten most important systems and who can access them.
- [ ] Accounts for former staff, freelancers and unused tools are removed.
- [ ] Every team member has been asked which AI tools they use, kindly.
- [ ] The team has one clear rule about what must not go into AI tools.
- [ ] Changes to bank details must be confirmed by phone, using a number we already hold.

- [ ] I have confirmed that at least one important backup can be restored.
- [ ] I know who to call if something goes wrong, and have written the number down.
- [ ] I have booked time to start Chapter 1.

WHAT TO DO TODAY **What to do today**

Finish the first three actions before you close this book: turn on multifactor authentication for your email, check for unknown forwarding rules, and write down your ten most important systems. Those three close several of the most common routes in.

PART

I

Understanding the Threat

What your business holds, what a mistake can cost, where you are exposed, and why people are both the weak point and the strongest defence.

PART I · UNDERSTANDING THE THREAT

CHAPTER

01

Your Data Is the Target

Why a small business holds information that other people want, and how it can be misused.

IN THIS CHAPTER

- The kinds of data a small business holds, and why each has value to others
- How stolen or exposed data is typically misused
- Why size does not protect you
- A first look at what you hold, using the DATA SHIELD METHOD

SOURCE NOTE **DATA SHIELD · D Discover**

This chapter is about discovery. You cannot protect what you have not named, so the first step is to see your data the way an outsider would.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the freelancer's laptop**

Marta is a freelance marketing consultant with four regular clients. Her laptop holds campaign reports, client customer lists exported from email tools, saved passwords in her browser, and scans of two signed contracts. Her email account is also the recovery address for most of her other accounts. One evening she clicks a link in what looks like a file-sharing notice. Nothing visibly happens. Three weeks later a client asks why a stranger has been emailing their customers using Marta's name.

Why it matters

Marta's story is invented, but the pattern is familiar. A single compromised account can reach many people, because small businesses sit in the middle of relationships: with customers, suppliers, employees and clients. Anyone who gets into your email can write to all of them, and they will believe the message because it came from you.

There is a second reason it matters. Under the GDPR, the personal data you hold about customers and employees is not only your asset. It belongs, in a legal sense, to the people it describes, and you are responsible for protecting it. Article 5(1)(f) requires personal data to be processed in a way that ensures appropriate security, and Article 32 requires appropriate technical and organisational measures [1]. "Appropriate" is judged against the risk, so a small shop and a hospital are not held to the same standard, but neither is free of one.

Seven kinds of data worth stealing

What you hold and why others want it

Data	Examples	How it can be misused
Customer records	Names, emails, addresses, phone numbers, order histories	Phishing and scams that quote real orders; identity fraud; resale
Payment and financial details	Invoices, bank details, card tokens, payroll	Invoice redirection, fraudulent payments, extortion
Credentials	Passwords, API keys, admin logins, access tokens	Account takeover; impersonation; access to everything else
Supplier and partner details	Contacts, contract terms, price lists	Impersonating a supplier; undercutting; targeting your partners
Employee information	Contracts, ID numbers, bank details, health notes, performance data	Identity theft, targeted fraud, serious harm if sensitive details leak
Business secrets	Pricing, plans, designs, source code, client lists	Competitive harm; extortion; loss of advantage
Your reputation and access	Social accounts, your domain, your email identity	Scams in your name; loss of customer trust

> **IN PLAIN ENGLISH** **In plain English**
>
> "Personal data" means any information that relates to an identifiable person, directly or in combination with other information (GDPR Article 4(1)) [1]. A name is personal data. So is an email address, an IP address, or a customer number that can be traced back to someone.

Why size does not protect you

Many cyber threats are untargeted. A phishing email goes to thousands of addresses, and the ones that pay off are the ones where someone clicks. Criminals do not need to know your business exists. They only need one weak password or one unpatched system. ENISA's guidance for SMEs recognises that smaller organisations face the same kinds of threat as larger ones with fewer resources to meet them [16]. The practical lesson is that **a small business is often an easy path to a bigger prize**, such as the customers it serves or the larger company it supplies.

WATCH OUT **Do not exaggerate, do not ignore**

Not every business will be attacked, and not every attack succeeds. But the cost of preparation is usually small compared with the cost of recovery, and many of the best defences are cheap. This book asks for proportion, not panic.

HYPOTHETICAL EXAMPLE **Hypothetical case study: the bakery's customer list**

A bakery with three branches runs an online ordering page. The owner stores the customer export, with names, addresses and allergy notes from orders, in a shared spreadsheet that anyone with the link can open. A former employee still has the link in their email. Nobody has attacked the bakery. But allergy notes can reveal health information, which the GDPR treats as special-category data under Article 9, and a link that anyone can open is a standing exposure. The fix is not dramatic. The owner restricts the sheet to named staff, removes the former employee's access, deletes allergy notes once an order is fulfilled, and records the change. It takes an afternoon.

How exposed data is typically misused

Data does not have to be sold or published to cause harm. The common patterns are ordinary:

- **Convincing phishing.** A scam message that quotes a real order, name or invoice number is far harder to doubt.
- **Account takeover.** A password leaked from one service is tried on many others.
- **Invoice and payment fraud.** Real supplier and customer details make a fake "changed bank account" request believable.
- **Identity fraud.** Copies of identity documents, dates of birth and addresses can be used to open accounts in someone else's name.
- **Extortion.** Criminals may threaten to publish or sell data unless paid.
- **Resale.** Customer and employee lists can be sold and reused for years.
- **Competitive harm.** Pricing, plans and client lists can reach rivals.

None of these needs advanced skill, which is why basic controls matter so much.

Common mistakes and misconceptions

Myths about being a target

Misconception	What is actually true
"We are too small to be interesting."	Many attacks are automated and indiscriminate. Size rarely helps.
"We have nothing valuable."	Customer lists, credentials, email access and invoices all have value to others.
"Security is the IT person's job."	Most small businesses have no IT person. Security habits are everyone's.
"We have not been hacked, so we are fine."	Many problems go unnoticed for a long time. Absence of evidence is not evidence of safety.
"The cloud provider handles it."	Providers secure their infrastructure. Your settings, passwords and sharing choices remain yours.

Step by step: see your data like an outsider

1. **List the places data lives.** Email, cloud storage, accounting, payment platforms, your website, shared drives, phones and laptops, paper files.
2. **List the types of data in each.** Customer, employee, financial, credentials, secrets. Note anything sensitive, such as health or ID numbers.
3. **Ask who can reach it.** Name every person, contractor and tool with access, and mark anyone who no longer needs it.
4. **Ask what the worst case would be.** If this account were copied or locked tomorrow, what would break and who would be harmed?
5. **Rank them.** Mark your three most valuable or most exposed places. They are where Chapter 14 begins.

CHAPTER 1 CHECKLIST

- [ ] I can name the places where my business keeps customer data.
- [ ] I can name the places where it keeps passwords and payment access.
- [ ] I know who has access to each of them.
- [ ] I have noted any special-category data, such as health data.
- [ ] I have identified my three most valuable data locations.

WHAT TO DO TODAY **What to do today**

Spend 20 minutes writing down the five places that hold the most sensitive data in your business, and who can access each. A handwritten list is a perfectly good start.

Summary

- Small businesses hold customer, financial, credential, supplier, employee and secret data, all of which others can misuse.
- Size does not protect you, because many attacks are untargeted.
- Personal data carries legal duties, including security measures that are appropriate to the risk [1].
- The first step is Discovery: know what you hold and who can reach it.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 4(1), 5(1)(f), 9 and 32. [16] ENISA, *Cybersecurity guide for SMEs*. See the Sources section for links and how each was checked.

PART I · UNDERSTANDING THE THREAT

CHAPTER

02

The Hidden Cost of a Digital Mistake

Disruption, money, regulators, trust and recovery: what a mistake can cost, and which numbers you can trust.

IN THIS CHAPTER

- The six kinds of cost: operational, financial, regulatory, customer trust, reputational and recovery
- What the GDPR says about fines and damages, and what it does not
- How to tell documented evidence from estimates
- A simple way to estimate your own exposure

SOURCE NOTE **DATA SHIELD · A Assess**

This chapter introduces assessment. Before you can decide what to protect first, you need a realistic idea of what each kind of failure would cost your business.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the Monday morning lock-out**

A small architecture studio arrives on Monday to find that nobody can open any project file. A message demands payment. The studio has backups, but they were last tested two years ago, and nobody remembers the password to the backup system. For four days, no one can bill a client, send a drawing or answer a deadline. One client, losing patience, moves a project elsewhere.

Six ways a mistake costs money

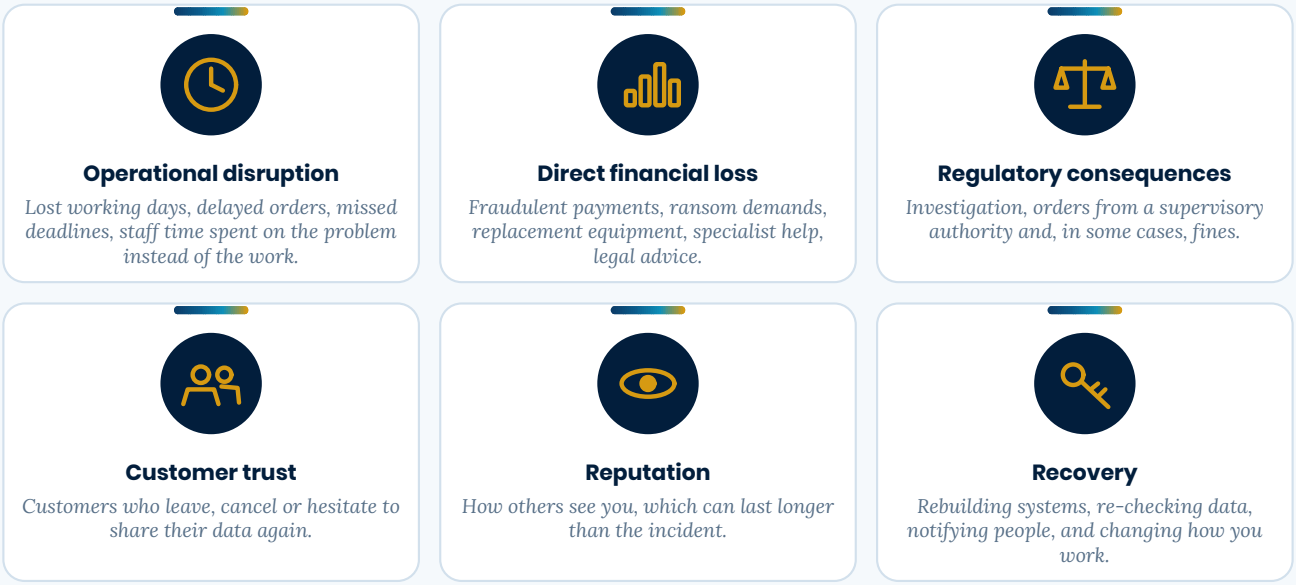


Figure 4 The cost types

What the law says about fines and damages

The GDPR sets maximum fines in two tiers (Article 83). For some infringements, such as failures of the security and notification duties in Articles 25 to 39, the maximum is **EUR 10 million or 2% of worldwide annual turnover**, whichever is higher, for an undertaking. For others, such as breaches of the basic principles, consent rules, individuals' rights and international transfer rules, the maximum is **EUR 20 million or 4%** [1].

> **WATCH OUT** **Maximums are not typical fines**
>
> Those figures are **ceilings**, not predictions. Article 83(2) requires supervisory authorities to consider the nature, gravity and duration of the infringement, whether it was intentional or negligent, the steps taken to reduce harm, cooperation, and other factors. Fines must be effective, proportionate and dissuasive. Most cases involving small organisations do not approach the ceiling. Do not assume that a small mistake means a catastrophic fine, and do not assume it means none.

Supervisory authorities also have other powers under Article 58, including warnings, reprimands, orders to comply and temporary or definitive limits on processing [1]. For a small business, an order to stop using a system can be as disruptive as a fine.

Individuals have separate rights. Article 82 gives anyone who has suffered material or non-material damage from an infringement a right to compensation [1]. The Court of Justice of the EU has said there is no minimum threshold of seriousness for non-material damage, although the person must show actual damage and a link to the infringement [25]. Claims are decided on their facts, and the case law keeps developing.

Evidence versus estimates

Cost figures are tempting and often unreliable. Headline numbers about the "average cost of a breach" come from surveys and models, vary by country and industry, and usually describe large organisations. This book does not quote them. If you meet such a figure, ask four questions: who produced it, how was it measured, whose experience does it describe, and when? A figure you cannot trace is an estimate at best.

How to treat a cost claim

Kind of claim	How much to trust it	Example
Legislation	Binding and checkable	The Article 83 fine ceilings [1]
Regulator decisions and guidance	Checkable, specific to facts	A published decision of a supervisory authority
Court judgments	Binding for the question decided	CJEU rulings on damages [25]
Industry surveys and reports	Useful but methodology-dependent	Annual breach-cost surveys
Anecdotes and headlines	Illustrative only	"One in X businesses..." without a source

HYPOTHETICAL EXAMPLE **Hypothetical case study: the wrong attachment**

A four-person recruitment agency emails a candidate shortlist to a client. The attachment contains a hidden sheet with the full applicant list: names, phone numbers and current salaries. The client forwards it to a colleague before anyone notices. No criminal is involved, but the agency must now work out who received what, assess the risk to the candidates, decide whether Article 33 requires notification, and explain itself to applicants. Hours of work, strained relationships and some lost business follow. The fix is cheap: check attachments before sending, remove hidden sheets, and use a shared link with expiry for sensitive lists.

Insurance, contracts and customers

Three things often decide how bad an incident becomes. **Insurance:** a cyber or business policy may cover some costs, but it usually has conditions, such as having multifactor authentication or tested backups, and exclusions. Read it before you need it, and note any notification deadline it imposes. **Contracts:** client agreements may require you to meet security standards, to tell the client quickly if their data is affected, and to bear some losses. **Customers:** people whose data was involved may complain to the supervisory authority under Article 77 or claim compensation under Article 82 [1]. A clear, honest and prompt response is both the right thing to do and the best way to limit all three.

Common mistakes and misconceptions

Assumptions about cost

Misconception	Reality
"Fines are the main risk."	For most small businesses, disruption, lost customers and staff time cost more than any fine.
"Insurance covers everything."	Policies have conditions and exclusions. Read yours, and ask what security measures it requires.
"If we are small, the fine will be small."	Fines depend on the facts and on turnover. Do not assume either way.
"Recovery is just restoring a backup."	Recovery includes checking what was affected, telling people, and fixing the cause.

Step by step: estimate your own exposure

1. **Pick one scenario.** For example: email account taken over for two days.
2. **Estimate the lost working time.** How many people, how many days, at what daily cost?
3. **Add direct costs.** Specialist help, replacement equipment, payments you might have to reverse.
4. **Add the revenue at risk.** Orders or invoices you could not process.
5. **Add the people you would have to tell.** Customers, partners, perhaps a supervisory authority.
6. **Write it down as a range, not a single number.** Label it an estimate. Use it to decide which control to buy first.

CHAPTER 2 CHECKLIST

- [ ] I have written one realistic incident scenario and estimated its cost as a range.
- [ ] I know what my cyber or business insurance covers, and what it requires.
- [ ] I know where my most important data is backed up.
- [ ] I understand that fine ceilings are maximums, not predictions.
- [ ] I treat unsourced statistics with caution.

WHAT TO DO TODAY **What to do today**

Write a three-line scenario for your business: what happens, who is affected, what it costs per day. Keep it for Chapter 18.

Summary

- Costs come in six kinds, and disruption often outweighs fines.
- The GDPR sets fine ceilings of EUR 10 million or 2% and EUR 20 million or 4%, but fines depend on facts and are not automatic [1].
- Individuals can claim compensation under Article 82 [1][25].
- Trust documented evidence over unsourced statistics.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 58, 82 and 83. [25] CJEU, Case C-300/21 (4 May 2023). Working knowledge. Verify before relying.

PART I · UNDERSTANDING THE THREAT

CHAPTER

03

Your Digital Attack Surface

The places an outsider, or an accident, can reach your business: email, websites, cloud, devices, payments and more.

IN THIS CHAPTER

- What "attack surface" means in plain English
- The nine areas where small businesses are commonly exposed
- How remote working and connected devices change the picture
- How to draw a simple map of your own exposure

SOURCE NOTE **DATA SHIELD · D Discover**

Discovery continues here, moving from data to systems. Each system is a door. The goal is to count them.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the forgotten website plug-in**

A small travel agency's website runs on a popular content-management system. A plug-in added years ago for a photo gallery has not been updated since. Nobody remembers installing it. One day the site starts redirecting visitors to an unrelated page. The agency's booking form, which collects passport details, sits on the same server.

Your **attack surface** is the sum of all the places where someone could try to get in, or where information could get out by accident. It is not a technical term only for experts. If you can list the ways into your office building, you can list the ways into your digital business.

Nine areas to check

Where small businesses are commonly exposed

Area	What is exposed	A typical weakness
Email	Messages, attachments, password resets	Reused passwords; no multifactor authentication; phishing
Website and online shop	Customer accounts, forms, payment pages	Outdated plug-ins; weak admin passwords; unneeded data collected
Cloud storage and file sharing	Documents and exports	Links open to anyone; former staff keep access
Software as a service (SaaS) apps	CRM, accounting, HR, marketing tools	Dozens of accounts, no one list, excessive permissions
Mobile devices	Email, chat, authenticator apps	No screen lock; lost or stolen; personal and work mixed
Payment platforms	Bank, card and invoicing access	Single login shared by several people; no change alerts
Social media	Brand accounts and direct messages	Shared passwords; no second step; old admins
Connected devices	Printers, cameras, routers, smart locks	Default passwords; no updates
Remote working	Home networks, personal laptops	Unmanaged devices; public Wi-Fi; shared family computers

What has changed

Ten years ago most small business data sat in one office. Today it is spread across tools, devices and homes. The change brings freedom, and also **sprawl**: more doors, more accounts, more people with access, and no one place to look. Sprawl is the real enemy. A business with eight well-managed tools is usually safer than one with forty unmanaged ones.

AI tools as a new door

Many businesses have added a new door without noticing: AI tools. Staff may use chat assistants, transcription apps, writing aids and browser extensions. Some may be connected to email or shared drives. Each deserves a place on your map, and Part II returns to them in depth.

> **HYPOTHETICAL EXAMPLE** **Hypothetical case study: the shared login**
>
> A small design agency uses one shared login for its social media accounts, known to six people, three of whom no longer work there. A former freelancer, annoyed about an unpaid invoice, posts an offensive message from the brand account. No data is stolen, but the damage to reputation is real. The fix: individual accounts with multifactor authentication, a password manager for any truly shared credentials, and a routine of removing access when people leave. The agency also records who owns each account.

Remote work and personal devices

Home working spreads your business across homes, cafés and personal devices. The questions are the same as in the office: who can reach the data, from what device, over what network? Prefer company-managed laptops with encryption and automatic updates. If people use personal devices, require a screen lock, updates and a separate work profile, and be clear that you may need to remove work data if they leave. Avoid saving work files to personal cloud accounts. Public Wi-Fi is acceptable for ordinary web browsing over encrypted connections, but use a trusted secure connection for anything sensitive.

Shadow IT: the tools nobody told you about

"Shadow IT" means services that people sign up for without anyone approving them: a free file-transfer site, a note-taking app, a browser extension, an AI assistant. It is rarely malicious. People simply want to get work done. The answer is not to catch people out but to make the approved route easy and to ask openly what is in use. Your map from this chapter is the first step.

Common mistakes and misconceptions

Surface myths

Misconception	Reality
"Only the website matters."	Email is the most common route in, and it controls your password resets.
"Personal phones are not part of the business."	If work email or authenticator apps live there, they are.
"We use well-known tools, so they are safe."	A good tool with weak settings is still a weak door.
"We do not have any connected devices."	Printers, routers and cameras count.

Step by step: map your surface

1. **Write the nine areas as headings** on one sheet of paper.
2. **Under each, list what you actually use.** Tool names, device types, who owns them.
3. **Mark which hold personal data or payment access.** These matter most.
4. **Mark which have no second step for login.** These are your quickest wins.
5. **Circle anything nobody owns.** An unowned tool is a risk waiting.

CHAPTER 3 CHECKLIST

- [ ] I have listed my email, website, cloud, SaaS, devices, payments, social media and connected devices.
- [ ] Each system has a named owner.
- [ ] I know which systems lack multifactor authentication.
- [ ] I have listed the AI tools in use, including free accounts.
- [ ] I know who works remotely and on what devices.

WHAT TO DO TODAY **What to do today**

Draw the one-page map. Mark in red every item with no multifactor authentication. That is tomorrow's to-do list.

Summary

- Your attack surface is every way into or out of your business.
- Sprawl, meaning many tools, accounts and devices with no owner, is the main small-business problem.
- AI tools are a new surface that most businesses have not mapped.
- A one-page map is enough to start.

SOURCE NOTE **Key sources**

[16] ENISA, *Cybersecurity guide for SMEs*. [17] NIST, *Cybersecurity Framework* 2.0 (the "Identify" function). [22] OWASP, *Top 10 for LLM Applications* (for AI-related risks).

PART I · UNDERSTANDING THE THREAT

CHAPTER

04

The Human Factor

Phishing, impersonation, weak passwords, excess access and honest mistakes: the people side of security.

IN THIS CHAPTER

- The seven most common human-factor failures
- How phishing and social engineering work, in plain terms
- Why blame fails and a good reporting culture works
- A simple staff awareness routine you can run in an hour a quarter

SOURCE NOTE **DATA SHIELD · A Assess and S Safeguard**

People are part of every system. Assessing them means looking at habits and access, and safeguarding them means training, clear rules and a culture in which it is safe to report a mistake.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the urgent email from the boss**

Ivana, the office manager at a small import firm, receives an email that appears to come from the owner: "I am in a meeting. Need you to pay this supplier today, details attached. Please keep it between us." The address is almost right, with one letter changed. Ivana, wanting to help, begins to prepare the transfer.

Seven human-factor risks

Where people-related incidents begin

Risk	What it looks like	What helps
Phishing	A message that tricks you into clicking, logging in or opening a file	Training; multifactor authentication; a quick way to report
Impersonation	Someone pretends to be a boss, supplier or bank	Call-back rules for payments and changes
Social engineering	Pressure, urgency or friendliness used to get information	Permission to say "I need to check"
Weak or reused passwords	The same simple password on many sites	A password manager and unique passwords
Excessive permissions	People who can reach far more than they need	Least privilege, and regular review
Accidental disclosure	Wrong recipient, wrong attachment, wrong link setting	Slow down on sensitive sends; check before you share
Insufficient awareness	People who were never told what to look for	Short, regular, practical training

IN PLAIN ENGLISH **In plain English**

"Social engineering" means manipulating people rather than breaking technology. The attacker does not guess a password. They persuade you to give it away.

Why blame does not work

If employees fear punishment, they hide mistakes, and the longer a mistake stays hidden the more it costs. The most useful rule for a small business is: **report fast, and nobody is punished for an honest mistake.** The GDPR itself reinforces speed. A controller that becomes aware of a personal data breach has a limited time to notify the supervisory authority in some cases (Article 33), so an hour lost to embarrassment can matter [1]. Chapter 16 covers this.

Warning signs of a phishing or impersonation attempt

- Urgency, secrecy or threats: "do this now", "do not tell anyone", "your account will be closed".
- Slightly wrong sender addresses, domains or spellings.
- Unexpected attachments or links, even from known contacts.
- Requests to change bank details, share passwords or buy gift cards.
- Messages that bypass your usual process.

HYPOTHETICAL EXAMPLE **Hypothetical case study: the honest report**

At a small accountancy practice, a junior employee clicks a link in a fake delivery notice and enters their email password. Realising straight away, they tell the practice manager within ten minutes. The manager changes the password, signs out all sessions, checks for forwarding rules, and notes what happened. No client data was accessed. The practice thanks the employee publicly and adds the example to its next training session. Because the report was fast and welcomed, a possible incident stayed small.

Passwords and permissions in practice

The most effective password advice for a small team is short. Use a **password manager** so nobody has to remember dozens of logins. Use **long passphrases**, which are easier to remember and harder to guess, for the few passwords you do type, such as the manager's master password. Do not reuse passwords. Turn on **multifactor authentication** everywhere it is offered, starting with email. NIST's digital identity guidance supports long passphrases and checking against known-leaked passwords, and advises against forcing frequent arbitrary changes [18].

On permissions, use separate **administrator** and **everyday** accounts, so that a phishing click on the everyday account cannot change settings. Give shared mailboxes and shared drives named owners. Review who has access to what at least twice a year, and whenever someone changes role. The test for each permission is the same: **does this person need this to do their job?**

Common mistakes and misconceptions

Human-factor myths

Misconception	Reality
"Our people are smart, they will spot it."	Skilled people are fooled too, especially under time pressure.
"Training once is enough."	Habits fade. Short, regular reminders work better.
"Strong passwords are enough."	Passwords leak. A second step stops most account takeovers that start with one.
"Only juniors make mistakes."	Owners and managers are the favourite impersonation targets, and often have the most access.

Step by step: a one-hour quarterly routine

1. **Show two real-looking examples** of phishing messages from your own inbox, with details removed.
2. **Walk through the warning signs** above and ask people what they notice.
3. **Restate the rules.** Payments and bank changes need a call-back. Passwords go in the manager. Report anything odd.
4. **Explain how to report**, with a name and a number.
5. **Thank people for reporting.** Make it safe.

CHAPTER 4 CHECKLIST

- [ ] Every person has a unique login and uses multifactor authentication where possible.
- [ ] Payment and bank detail changes require a call-back check.
- [ ] There is a named person to report to, and everyone knows who it is.
- [ ] Access is reviewed at least every six months.
- [ ] Staff have had a short awareness session this year.

WHAT TO DO TODAY **What to do today**

Send your team one short message: "If something looks wrong, tell me straight away. Nobody will be in trouble for reporting." Include a name and number.

Summary

- People are both the most common entry point and the best sensor you have.
- Phishing, impersonation and weak passwords are the commonest routes; accidents are next.
- A culture of fast, unpunished reporting reduces damage.
- Regular, short training beats a single long session.

SOURCE NOTE **Key sources**

[1] GDPR, Article 33. [7] EDPB, *Guidelines 9/2022 on personal data breach notification.* [16] ENISA, *Cybersecurity guide for SMEs.* [17] NIST, *Cybersecurity Framework* 2.0 (the "Protect" function).



PART

II

AI Privacy: The New Business Risk

AI tools can speed up a small business, and can quietly move its most sensitive information to places nobody approved.

PART II · AI PRIVACY

CHAPTER

05

Before You Paste It Into AI

The risks of putting customer records, contracts, finances and secrets into AI tools, and a four-level way to decide.

IN THIS CHAPTER

- Why pasting into an AI tool is different from, and easier than, sending an email
- Four levels of information: public, internal, confidential and personal or sensitive
- Which kinds of data to keep out of AI tools unless you have clear approval and safeguards
- A five-second test you can teach your team

SOURCE NOTE **DATA SHIELD · D Discover and T Tighten**

Discovery here means knowing which kinds of information your business has and where they might travel. Tightening starts with a simple rule that staff can apply in seconds.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the helpful paste**

Dario manages sales at a ten-person software reseller. Before a renewal call, he pastes an email thread with a client into a free AI chat assistant, signed in with his personal account, and asks for a summary. The thread contains the client's pricing, a named contact's mobile number, a complaint about a staff member and a discount Dario's boss has not yet approved. The summary is excellent. The call goes well. Nobody did anything malicious. But Dario's firm cannot now say which service holds that thread, under what terms, for how long, or whether anyone at the provider can see it.

Why this is a new kind of risk

Sending a confidential email to an outsider needs an address, a decision and a click on Send. Pasting the same text into a chat window needs a keystroke, and it feels like thinking aloud. That **frictionlessness** is the risk. The act is easy, the destination is a service run by another company, and what happens next depends on that company's terms, your account type and your settings.

AI tools are not uniformly dangerous. Many providers publish serious privacy and security commitments, and some business plans offer strong contractual protection. But those commitments differ between providers, between products and between plans. **The same brand can mean different rules on a free personal account and a paid business account.** This chapter is therefore about deciding what goes in; Chapters 6 and 7 are about choosing and contracting for the tool.

Four levels of information

Public

Already published or intended for the public: your website text, price list, published blog posts.

Approved tool · Check accuracy

Internal

Everyday business information not meant for outsiders but not seriously harmful if exposed: internal procedures, meeting notes without names or figures.

Approved tools only · Remove what is not needed

Confidential

Information whose disclosure could harm the business or breach a contract: pricing, unreleased plans, client files, source code, financial results, material under a non-disclosure agreement.

Approved business tool · Minimise first · Reviewed contract · Often not at all

Personal or sensitive

Personal data about identifiable people; and special-category data such as health, ethnicity, religion, trade-union membership, biometrics used to identify, sexual orientation; criminal data; children's data; identity documents; payment details; passwords and keys.

Lawful basis and notice · No special-category data without approval · Never credentials or ID

Figure 5 Four levels, from open to closed

IN PLAIN ENGLISH **In plain English**

Personal data is information that relates to an identifiable person. Special-category data, listed in Article 9 of the GDPR, is a subset that the law protects more strictly because misuse can cause serious harm [1]. Confidential business information is a separate idea. It may not be personal data at all, but contracts and trade-secret rules may still protect it [24].

What carries the most risk

- **Customer and client records.** Names, contact details, order histories, support tickets, anything that identifies a person.
- **Contracts and legal documents.** They may contain pricing, obligations and personal details, and may be covered by confidentiality clauses.
- **Financial information.** Bank details, invoices, management accounts, payroll.
- **Employee information.** Performance reviews, health notes, disciplinary matters, salary details.
- **Strategy and trade secrets.** Plans, designs, code, formulas, client lists.
- **Credentials.** Passwords, API keys, tokens and recovery codes. Never paste these into any AI tool.
- **Anything about children or health.** Both are subject to special care under the GDPR.

Why deleting names is not enough

Many people assume that removing a name makes information safe. It often does not. A "58-year-old finance director at a nine-person firm in a small town who returned from sick leave in March" may point to exactly one person for anyone who knows the town. **Anonymous** information, in the GDPR sense, is information from which a person cannot be identified by any means reasonably likely to be used. **Pseudonymised** information, where names are replaced by codes but a key exists, is still personal data (Article 4(5) and Recital 26) [1]. Whether a given data set counts as personal data can depend on who holds it and what other information they can reach, a point the Court of Justice has explored in recent case law [27]. For a small business the practical rule is simple: **if the details could point to a real person, treat the text as personal data.**

HYPOTHETICAL EXAMPLE **Hypothetical case study: the clinic's summary**

A small physiotherapy clinic asks an AI tool to "summarise this patient's progress for a referral letter", pasting the clinical notes with the patient's name removed. The notes still include age, occupation, a distinctive injury and the date of a surgery at the local hospital. Anyone at the clinic, and likely anyone in the town, could tell who it was. Because the notes are health data, the clinic has special-category data in an unapproved tool. The fix: use an approved tool under a proper contract if it uses AI at all, or draft the letter from a structured template without the AI. The clinic also adds a "never paste patient notes" rule and records the decision.

The five-second test

		YES	NO
1	**Does it contain a password, key, token or recovery code?**	STOP. Never paste secrets.	Go to question 2.
2	**Is the tool approved by my business for this purpose?**	Go to question 3.	STOP. Use an approved tool or ask for approval.
3	**Does it include special-category data, children's data, ID documents or payment details?**	STOP. Do not proceed without specific approval.	Go to question 4.
4	**Does it include personal data about customers, staff or others?**	Remove or replace identifying details if the task allows, then ask again.	Go to question 5.
5	**Is it confidential business information or covered by an NDA or client contract?**	Check the contract and the tool's terms. Minimise.	You can proceed. Check the answer before using it.

Figure 6 Should this go into this AI tool?

Special situations

- **Employee data.** Staff are individuals with rights too. Performance reviews, health notes, disciplinary records and salary details are rarely suitable for AI tools, and national employment law adds its own limits.
- **Children's data.** The GDPR gives children's data particular attention (for example in Article 8 and Recital 38) [1]. Treat it as off-limits unless you have a clear, documented basis and an approved tool.
- **Client confidentiality and legal privilege.** Professionals such as lawyers, accountants and consultants may owe duties of confidentiality that are stricter than the GDPR. Check your professional rules and client contracts before using AI.
- **Source code and credentials.** Code can contain keys, tokens and passwords, and unreleased code is often a trade secret. Never paste secrets, and treat proprietary code as confidential.
- **Contracts and NDAs.** A non-disclosure agreement may forbid sharing the document with any third party, including an AI service.

Common mistakes and misconceptions

AI privacy myths

Misconception	Reality
"If I delete the chat, it is gone."	Deleting from your history may not remove every copy or log. Check the provider's retention terms.
"Removing the name makes it anonymous."	Indirect details can still identify a person.
"It is only a summary."	A summary of personal data can itself be personal data.
"Everyone else uses it."	Common use is not a lawful basis or a contract.
"It is a trusted brand."	The plan and settings matter more than the logo.

Step by step: introduce a first rule

1. **Define your four levels** with examples from your own business.
2. **Write a never-paste list.** Credentials, special-category data, ID documents, payment card details, anything under NDA.
3. **Name the tools that are approved**, even if the list is one tool long.
4. **Tell the team and explain why.** A rule with a reason is followed more often.

CHAPTER 5 CHECKLIST

- [ ] I have written examples of public, internal, confidential and personal or sensitive information from my own business.
- [ ] I have a written never-paste list.
- [ ] Staff know which AI tools, if any, are approved.
- [ ] Staff know that removing a name does not always make data anonymous.
- [ ] Nobody uses a personal AI account for customer or confidential data.

WHAT TO DO TODAY **What to do today**

Write a three-line message to your team: what must never go into an AI tool, which tool is approved, and whom to ask. Send it.

Summary

- Pasting is frictionless, so the decision has to be made before the paste.
- Use four levels: public, internal, confidential, and personal or sensitive.
- Keep credentials, special-category data and ID documents out of AI tools.
- Removing a name does not always make information anonymous.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 4(1), 4(5), 9 and Recital 26. [15] EDPB, *Opinion* 28/2024 on AI models. [24] Directive (EU) 2016/943 on trade secrets. [27] CJEU, Case C-413/23 P. Working knowledge. Verify before relying.



PART II · AI PRIVACY

CHAPTER

06

Using AI Without Exposing Your Business

A practical framework for safer AI adoption: approved tools, minimisation, access limits, human review and a simple staff policy.

IN THIS CHAPTER

- Eight building blocks of safer AI use
- How to minimise, redact and anonymise before you ask
- How to review AI output and keep a human accountable
- What a one-page staff policy should say

SOURCE NOTE **DATA SHIELD · T Tighten and A Account**

Tightening means putting controls around AI use. Accounting means writing the rules and decisions down, so that they can be shown and kept up to date.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: two employees, two habits**

At a small marketing agency, Lea uses an approved business-plan AI tool to draft campaign ideas from a brief that has the client's name and budget removed. Tomas pastes a client's full customer survey, with names and email addresses, into a free assistant on his phone to "find the themes". They both finish quickly. Only one of them has created a problem.

Eight building blocks

01
Approved tools only
Decide which AI tools the business allows, on which plans, for which purposes. Ban personal accounts for work data.

02
Data minimisation
Share only what the task needs. Describe the situation rather than pasting the document.

03
Anonymisation and redaction
Replace names, numbers and identifiers with placeholders. Remember that this may not be enough.

04
Access restrictions
Limit who can use each tool, and what it can connect to. Prefer the least access that works.

05
Human review
A person checks every AI output before it is sent, published or used to decide something about someone.

06
Vendor assessment
Check the provider's terms, security and data practices for the plan you use (Chapter 7).

07
Staff policy
A short, clear written policy that every user has read.

08
Record and review
Keep a list of tools and decisions. Review it at least twice a year.

Figure 7 A framework for safer AI use

Minimise before you ask

The best protection is not to send what you do not need. Describe the situation, not the person.

BEFORE & AFTER **Drafting a customer reply**

RISKY	*Paste the full email: "Hi, I'm Ana Horvat, 12 Park Street. My card ending 4417 was charged twice for order 88412 and I have been unwell so please hurry. Call me on 091 555 0199."*
BETTER	*"A customer says they were charged twice for one order and asks for a quick reply. Draft a polite response explaining that we will check payment records and reply within two working days."*
BEST PRACTICE	*Use an approved tool and a prompt template with placeholders: "Customer: [NAME]. Issue: possible duplicate charge. Tone: warm and concise." Add real details only in your own system when you send the reply.*
WHY IT MATTERS	The better prompts describe the situation rather than the person. The address, card digits, health remark and phone number were never needed to draft a reply.

Review the output

AI output can be wrong, can repeat information from the input, and can sound more certain than it is. A person must stay accountable. If AI is used to produce something that affects a customer or employee, such as a refusal, a ranking or a contract clause, someone has to read it, understand it and own the result. The GDPR also restricts decisions based **solely** on automated processing that have legal or similarly significant effects on a person (Article 22) [1]. The Court of Justice has applied this to automated scoring in a recent case [26]. If you use AI near decisions about people, take advice.

A one-page staff policy

You do not need a long document. One page that says the following is far better than a long one nobody reads. Appendix B gives a template.

- Which AI tools are approved, and for what.
- What must never be entered.
- That outputs must be checked by a person.
- Who to ask when unsure, and how to report a mistake.
- That the policy will be reviewed, and by whom.

HYPOTHETICAL EXAMPLE **Hypothetical case study: a policy that worked**

A six-person consultancy discovered that three of its staff used different free AI tools. The owner did not ban them. She ran a half-hour session, picked one business-plan tool after reading its terms, listed what could and could not be entered, and asked everyone to move. The policy, one page, was signed by each person. Three months later a team member asked before pasting a contract. That question was the policy working.

Ten safe and useful ways to use AI

A good policy says yes as well as no. These uses usually involve little or no sensitive information, so long as you review the output:

- Brainstorming names, headlines and campaign ideas from a brief with no client data.
- Drafting a generic template, such as a meeting agenda or an onboarding checklist.
- Rewriting your own public text for tone or length.
- Explaining a published regulation or concept in plain language, which you then check against the source.
- Summarising a public report or article.
- Creating **synthetic** example data, with invented names and figures, to test a process.
- Outlining a training session or a policy structure.
- Suggesting spreadsheet formulas, with made-up sample data.
- Proofreading text that contains no personal or confidential details.
- Preparing questions for a meeting.

In every case, a person checks the result, and nothing confidential goes in.

Common mistakes and misconceptions

Mistakes with AI adoption

Mistake	Better approach
Ban all AI	A ban without an alternative pushes use underground. Offer an approved route.
Allow everything	Without limits, confidential and personal data will leak.
Trust the output	Always review. AI can invent facts and misstate the law.
Write a policy and forget it	Review twice a year. Tools and terms change.

Step by step: adopt AI in 30 days

1. **Week 1.** Ask what is in use. List tools and accounts.
2. **Week 2.** Choose approved tools, check their terms, and decide your never-paste list.
3. **Week 3.** Write the one-page policy and brief the team.
4. **Week 4.** Check in. Ask what worked and what did not. Adjust the policy.

CHAPTER 6 CHECKLIST

- [ ] I have a list of approved AI tools and plans.
- [ ] I have a written staff policy.
- [ ] A person reviews AI output before it is used externally.
- [ ] Nobody uses AI to make solely automated decisions about people without advice.
- [ ] I have a date to review the policy.

WHAT TO DO TODAY **What to do today**

Download or copy the policy template in Appendix B, fill in the tool names and send it to your team for comment.

Summary

- Use approved tools, minimise what you share and keep a person accountable.
- Policies work when they are short, clear and explained.
- Article 22 limits solely automated decisions about people [1].
- Review rules regularly, because tools and terms change.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 5, 22 and 25. [10] EDPB, *Guidelines 4/2019 on data protection by design and default*. [26] CJEU, Case C-634/21 (7 December 2023). Working knowledge. Verify before relying.

PART II · AI PRIVACY

CHAPTER

07

AI Vendors, Data Processing and Your Responsibilities

Who is the controller, who is the processor, and what to verify in a provider's terms.

IN THIS CHAPTER

- The difference between a controller, a processor, a joint controller and a third party
- Which role an AI provider usually has, and when it may have another
- What to look for in terms, data processing agreements, retention, sub-processors and transfers
- A short method for checking a specific service

SOURCE NOTE **DATA SHIELD · A Account and A Assess**

Accountability includes knowing your role and your supplier's role. Assessment means checking, rather than assuming, what a supplier does with your data.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the contract nobody read**

A small HR consultancy starts using an AI note-taking tool for interviews. A colleague accepted the terms by clicking "I agree". Months later a client asks: "Is the tool's provider your processor? Where are the recordings stored? Is there a data processing agreement?" Nobody knows.

Four roles

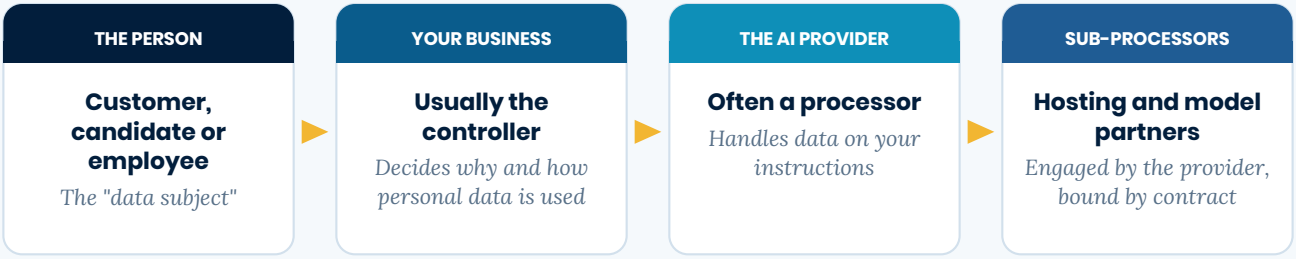


Figure 8 Who is who when a small business uses an AI tool

Controller, processor and others

Role	Meaning	Example
Controller (Art. 4(7))	Decides the purposes and means of processing	Your business, deciding to record interviews
Processor (Art. 4(8))	Processes personal data on behalf of the controller	An AI transcription provider acting on your instructions
Joint controllers (Art. 26)	Two or more decide purposes and means together	Rare for simple tool use; take advice
Third party / recipient	Another party that receives data	A provider that uses your data for its own purposes may be a controller in its own right

An AI provider is **often** a processor when you use its business service to process personal data on your behalf. But it may be a controller for some purposes of its own, such as account administration, security or, depending on the product and terms, improving its services. **Do not assume the role.** It depends on the product, the plan and the contract. The EDPB's guidelines on the concepts of controller and processor explain how to analyse it [6].

What the law requires of the contract

WHAT THE LAW SAYS **What the law says**

Article 28 requires that a controller uses only processors that provide sufficient guarantees, and that processing is governed by a contract or other legal act. The contract must set out the subject matter, duration, nature and purpose of processing, the type of personal data, the obligations and rights of the controller, and must include terms such as processing only on documented instructions, confidentiality, security measures, sub-processor conditions, assistance with individual rights and breach notification, and deletion or return of data at the end [1].

What to check in a specific service

A seven-point check of an AI service

Question	Where to look	What a good answer looks like
Which plan and product are we using?	Account settings, pricing page	A business plan with written terms, not a free personal account, if personal or confidential data is involved
Is there a data processing agreement (DPA)?	Provider's legal pages, sign-up flow	A DPA that is part of the contract and meets Article 28
Is our content used for training?	Privacy policy, product documentation	A clear statement for your plan, ideally that it is not used by default
How long is data retained, and can we delete it?	Retention documentation	Defined periods and a deletion route
Who are the sub-processors, and where do they operate?	Sub-processor list	A published list with a change-notice process
Where is data stored and transferred?	Data location and transfer terms	Clear location; a valid transfer tool where data leaves the EEA (Chapter 12)
What security assurances exist?	Security pages, certifications	Named standards and an incident notification commitment

WATCH OUT **Do not assume that all providers are the same**

Providers differ in their data practices and their contract terms, and the same provider may offer different terms for different products. **Verify the terms of the specific service you use, on the day you choose it, and again when something changes.** Keep a dated copy or screenshot of what you relied on.

HYPOTHETICAL EXAMPLE **Hypothetical case study: checking before buying**

A small law-adjacent consultancy considers an AI drafting assistant. Before purchase the owner works through the seven-point check. The provider offers a DPA on its business plan but not on its free plan, states that content from business plans is not used for model training by default, lists its sub-processors, and says data may be processed in a third country under standard contractual clauses. The owner records the date, saves the documents, chooses the business plan and bans the free version. The check took ninety minutes.

Red flags in terms and contracts

You do not need to be a lawyer to spot warning signs. Slow down if you see any of these:

- **No data processing agreement** on a plan that you intend to use for personal data.
- **Broad rights over your content**, such as a licence to use it for any purpose, or to improve services, without a way to switch it off.
- **Unclear data location** or no information about sub-processors.
- **Changes without notice.** The provider may change terms or sub-processors without telling you.
- **No deletion route.** Nothing about what happens to your data when you close the account.
- **Vague security language** with no named controls, certifications or incident-notification commitment.
- **Different terms for different plans**, where the cheaper plan quietly offers less protection.

A red flag is not always a reason to reject a tool. It is a reason to ask a question, record the answer and decide knowingly.

Common mistakes and misconceptions

Vendor myths

Misconception	Reality
"The provider is automatically a processor."	It depends on the product, plan and terms.
"A privacy policy is a contract."	A policy describes practice. A DPA is a contract.
"GDPR-compliant" on a website proves we are compliant.	Compliance belongs to the organisation using the tool for a purpose.
"A DPA means we can put anything in."	You still need a lawful basis, transparency and security.
"Terms never change."	They do. Re-check on a schedule.

Step by step: vet a provider in five steps

1. **Identify the exact plan and product.**
2. **Read the DPA and key terms.** Note roles, instructions, sub-processors, retention, transfers.
3. **Check training, retention and deletion for that plan.**
4. **Record the evidence and the date.** Save the documents.
5. **Decide, document and diarise a review.**

CHAPTER 7 CHECKLIST

- [ ] I know whether each AI tool is a processor or a controller for each purpose.
- [ ] Each approved tool has a DPA where personal data is involved.
- [ ] I have saved the terms I relied on, with the date.
- [ ] I have a review date for each tool.
- [ ] I know where each provider stores and transfers data.

WHAT TO DO TODAY **What to do today**

Pick the AI tool your team uses most and answer the seven questions above for it. Mark each answer "evidence", "unknown" or "not offered".

Summary

- Your business is usually the controller. A provider is often, not always, a processor.
- Article 28 requires a contract with specific terms [1].
- Terms differ by provider, product and plan, so verify the specific service.
- Keep dated evidence.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 4(7), 4(8), 26 and 28. [6] EDPB, *Guidelines 07/2020 on controller and processor*. See Chapter 12 for transfers.



PART II · AI PRIVACY

CHAPTER

08

Deepfakes, AI Fraud and Business Impersonation

Cloned voices, fake executives, fraudulent invoices and AI-assisted social engineering, and the verification habits that stop them.

IN THIS CHAPTER

- How AI makes impersonation and fraud more convincing
- The common patterns: cloned voices, fake video, fraudulent invoices, polished phishing
- Verification procedures for payments, account changes and urgent instructions
- How to train a team to pause without slowing the business

SOURCE NOTE **DATA SHIELD · S Safeguard**

Safeguarding here means procedures that do not depend on spotting a fake. If your process requires a second channel, a convincing fake still fails.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the call from the director**

The finance assistant at a small logistics company receives a phone call. The voice sounds exactly like the managing director, who is travelling. "A client needs an urgent deposit today. I will email the details. Please do it before the bank closes." The email arrives within minutes. It is polite, specific and urgent.

What AI changes

Fraud is not new. Fake invoices, spoofed emails and "CEO fraud" existed long before generative AI. What AI changes is **cost and polish**. Messages can be written in fluent, personalised language in any tongue. Voices can, in some cases, be imitated from short samples. Images and video can be altered. As a result, the old advice to "look for spelling mistakes" is less reliable, and the quality of a message is no longer evidence that it is genuine.

Europol and ENISA have both published general assessments of how criminals use AI, and the picture they describe is of existing fraud made cheaper and more convincing, not of entirely new crimes [23]. The defence is the same as it always was, with one adjustment: **stop relying on your senses, and start relying on process.**

Five common patterns

Impersonation and AI-assisted fraud

Pattern	What it looks like	Defence
Executive impersonation	A message or call from "the boss" demanding an urgent payment or gift cards	Call-back to a known number; two-person approval above a limit
Cloned voice	A call in a familiar voice asking for money or access	Agree a code word with key people; verify through another channel
Fraudulent invoice	A realistic invoice or a "changed bank details" notice from a supplier	Confirm changes by phone on a stored number; check against purchase orders
Fake video or image	A manipulated clip or photo used to add credibility	Do not rely on a clip alone for money or access decisions
Personalised phishing	Fluent messages using real details from social media or leaked data	Multifactor authentication; do not log in through links; report

Verification rules that work

1. **No payment or bank change on one channel alone.** Any new or changed bank details must be confirmed by a call to a number you already hold, not the one in the message.
2. **Two people for large or unusual payments.** Set a limit and stick to it.
3. **Urgency is a warning sign.** Anyone may say "I need to verify this first", and nobody is criticised for it.
4. **A code word for sensitive requests by phone.** Agree it in person with the few people who authorise money or access.
5. **Report and record.** Even failed attempts help you spot patterns.

GOOD PRACTICE **Good practice**

A rule works best when it applies to everyone, including the owner. If the managing director can bypass the call-back, a fraudster only needs to imitate the managing director.

HYPOTHETICAL EXAMPLE **Hypothetical case study: the call-back that saved a payment**

A small furniture importer receives an email from a long-standing supplier saying their bank account has changed. The email looks genuine, with a familiar signature. The bookkeeper follows the company rule, calls the supplier on the number in the contract, and learns that no change was requested. The supplier's email account had been compromised. The importer also tells the supplier, who secures the account. A rule that took two minutes prevented a loss and protected the supplier relationship.

If you have been tricked

Even careful businesses are sometimes fooled. Speed matters most. If money has been sent to the wrong account:

1. **Call your bank at once** and ask it to try to recall or block the payment. The first hours are often the most valuable.
2. **Stop further harm.** Change passwords, sign out sessions and check for forwarding rules on any account involved.
3. **Keep evidence.** Save emails, call logs, invoices and screenshots, with headers where possible.
4. **Report it** to the police or the relevant national fraud-reporting service.
5. **Tell the people affected,** such as the supplier whose details were copied, and your insurer if your policy requires it.
6. **Check for a personal data breach.** If personal data was disclosed or accessed, follow Chapter 16.

Common mistakes and misconceptions

Deepfake and fraud myths

Misconception	Reality
"I would recognise my boss's voice."	Voices can be imitated convincingly. Do not rely on recognition for payments.
"We would notice bad spelling."	AI-written messages are often fluent.
"Only big companies are targeted."	Invoice fraud and impersonation target businesses of all sizes.
"The call-back slows us down."	It takes minutes. A fraud takes weeks to unwind.

CHAPTER 8 CHECKLIST

- [ ] Bank detail changes need a call-back to a stored number.
- [ ] Large payments need two approvers.

- [ ] Key people have agreed a code word.
- [ ] Everyone knows it is fine to say "I will verify this".
- [ ] Fraud attempts, including failed ones, are recorded.

WHAT TO DO TODAY **What to do today**

Write the call-back rule in one sentence, send it to everyone who touches payments, and ask them to reply "understood".

Summary

- AI makes fraud more convincing, not fundamentally different.
- Rely on process rather than on spotting fakes.
- Verify payments and changes through a second, known channel.
- Make it normal, and safe, to pause.

SOURCE NOTE **Key sources**

[16] ENISA, *Cybersecurity guide for SMEs*. [23] ENISA Threat Landscape and Europol publications on criminal use of AI (general reading; no figures are quoted in this book).



PART

III

GDPR Without the Confusion

What the law actually asks of a small business, in plain English and in a workable order.

PART III · GDPR WITHOUT THE CONFUSION

CHAPTER

09

What GDPR Actually Requires From Your Business

Scope, key definitions, principles and what they mean for a small organisation, including the limited record-keeping exception.

IN THIS CHAPTER

- Who the GDPR applies to, including organisations outside the EU
- The key definitions, in plain English
- The seven principles of Article 5 and what they mean in practice
- Why small businesses are not exempt, and what the Article 30 exception really says
- A map of the articles this book covers

SOURCE NOTE **DATA SHIELD · D Discover and A Account**

Before you can organise compliance, you need to know whether and how the GDPR applies to you. Accounting means being able to show how you apply it.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: "but we are tiny"**

Petra runs a three-person translation business from a small town. She assumes the GDPR is for banks and tech companies. Then a client, a hospital, sends her a confidentiality questionnaire and a data processing agreement. She realises that she holds patient letters, invoices and email histories, and that her client treats her as its processor, with legal duties of her own.

Who the GDPR applies to

The GDPR applies to the processing of personal data by an organisation **established in the EU**, whatever the size of the organisation and wherever the processing takes place (Article 3(1)). It also applies to organisations outside the EU that offer goods or services to people in the EU, or monitor their behaviour there (Article 3(2)) [1]. Purely personal or household activity is excluded (Article 2(2)(c)), but running a business is not household activity. A freelancer, a shop, a club that processes members' data, a start-up and a charity are all within scope if they process personal data.

WATCH OUT **Small does not mean exempt**

There is no general exemption for small businesses. Some obligations are lighter in practice because they scale with risk, and one specific record-keeping duty has a limited exception for organisations with fewer than 250 employees, described below. The rest of the GDPR applies.

Key definitions, in plain English

The words you need

Term	Plain-English meaning	Where
Personal data	Any information about an identified or identifiable person	Art. 4(1)
Processing	Anything done with personal data: collecting, storing, using, sharing, deleting	Art. 4(2)
Controller	Decides why and how personal data is processed	Art. 4(7)
Processor	Processes data on behalf of a controller	Art. 4(8)
Data subject	The person the data is about	Art. 4(1)
Special-category data	Health, ethnicity, religion, politics, trade union, genetic, biometric, sex life or orientation	Art. 9
Personal data breach	A security breach leading to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of or access to personal data	Art. 4(12)
Consent	Freely given, specific, informed and unambiguous agreement	Art. 4(11), 7

The seven principles

Article 5 sets out the principles that run through everything else. Article 5(2) adds that the controller must be able to **demonstrate** compliance, which is the principle of accountability [1].

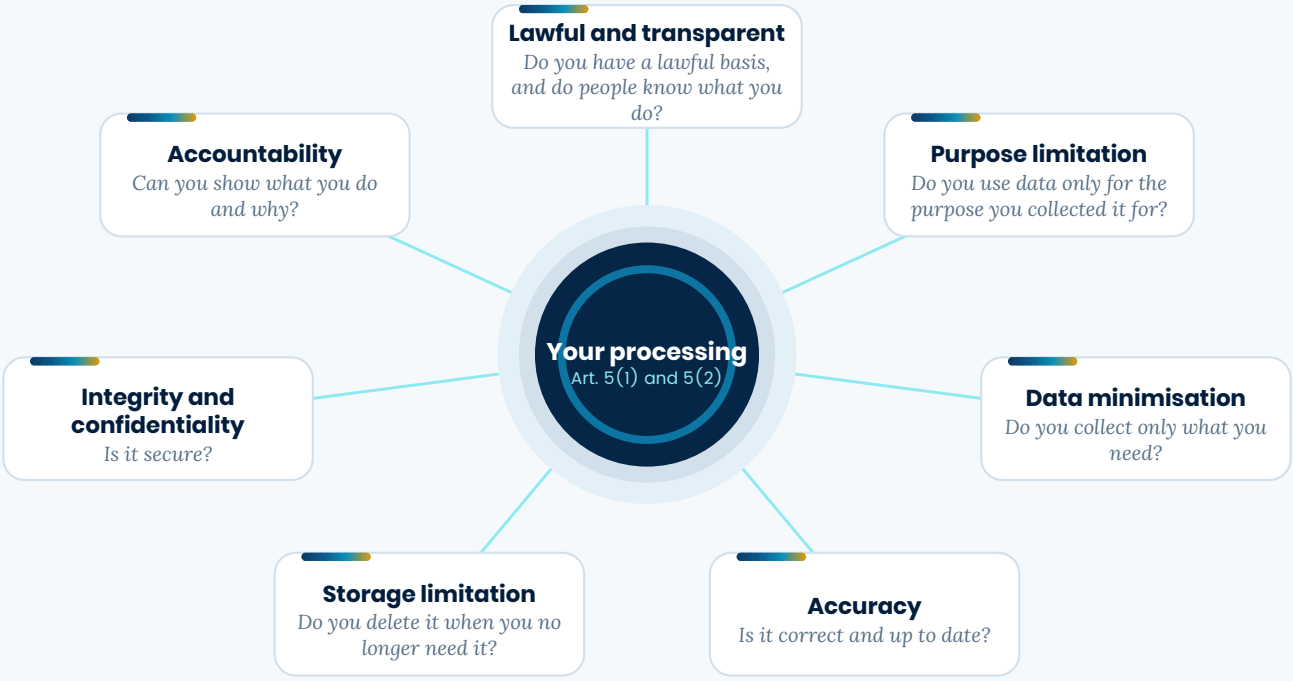


Figure 9 The principles of Article 5, applied to a small business

The articles this book covers

A map of the GDPR for small businesses

Articles	Subject	Chapter
5, 6	Principles; lawful bases	9, 10
12 to 22	Transparency and individuals' rights	11
25	Data protection by design and by default	13
28	Processors	7, 12
30	Records of processing	10
32	Security of processing	14
33, 34	Breach notification	16
35, 36	Data protection impact assessment	13
37 to 39	Data protection officer	13
44 to 49	International transfers	12
82, 83	Compensation and fines	2

The Article 30 exception: what it really says

Article 30 requires controllers and processors to keep a **record of processing activities**. Article 30(5) says the duty does not apply to an organisation employing **fewer than 250 persons**, but the exception falls away if **any one** of three things is true: the processing is **likely to result in a risk** to the rights and freedoms of individuals; the processing is **not occasional**; or the processing includes **special-category data** or data about criminal convictions and offences [1].

In practice the exception helps very few businesses. Almost every employer processes employee data regularly, which is not occasional. Many small businesses also hold health information or other special-category data. Keeping a simple record of processing is usually the safest and cheapest course, and the record is useful in its own right. Chapter 10 shows how to build one, and Appendix D gives a starter template.

SOURCE NOTE **Proposals are not law**

The European Commission's Digital Omnibus package proposed changes to some GDPR provisions. At the research cut-off of 24 October 2026, the data-protection part of the package had not, as far as could be verified, been adopted [3]. Do not rely on proposed changes until they appear in the Official Journal.

HYPOTHETICAL EXAMPLE **Hypothetical case study: Petra's first steps**

Petra reads the questionnaire carefully. She is a processor for her hospital client and a controller for her own invoices and marketing list. She lists what she holds, signs the client's processing agreement after reading it, writes a short privacy notice for her own customers, turns on multifactor authentication and records her decisions on two pages. It takes a weekend. She now has a clear answer when anyone asks.

Who enforces the GDPR

The GDPR is enforced mainly by national **supervisory authorities**, such as AZOP in Croatia, which can investigate, order changes and impose fines (Article 58 and Article 83) [1][19]. Individuals have the right to lodge a complaint with an authority (Article 77), and many authorities handle complaints about small businesses. Where processing affects people in several Member States, a "one-stop-shop" mechanism (Article 56) lets a lead authority coordinate, though a business operating in one country will usually deal with just one. Note, too, that information about people in a business setting is still personal data: an employee's work email address and a sole trader's name are within the GDPR, even if the transaction is business-to-business.

Common mistakes and misconceptions

GDPR myths

Misconception	Reality
"GDPR only applies to big companies."	It applies to any organisation processing personal data in scope.
"We have fewer than 250 staff, so we need no records."	The exception is conditional, and rarely applies in practice.
"Consent is always required."	Consent is one of six lawful bases (Chapter 10).
"Compliance is a one-off project."	It is ongoing. Accountability means keeping evidence.
"We are outside the EU, so it does not apply."	It can apply if you offer goods or services to people in the EU.

Step by step

1. **Decide your role.** Are you a controller, a processor or both?
2. **List what personal data you process.**
3. **Check each principle** against what you do.
4. **Decide whether you need a record of processing** (usually yes).
5. **Write down your decisions.**

CHAPTER 9 CHECKLIST

- [ ] I know whether I am a controller, a processor or both.
- [ ] I know that I am not exempt because of my size.
- [ ] I understand the Article 30(5) conditions and have decided how to keep records.
- [ ] I have read the seven principles.
- [ ] I know where to find the official text.

WHAT TO DO TODAY **What to do today**

Write one paragraph: "We process personal data of [customers, employees, suppliers] for [purposes]. We are the controller for [..] and a processor for [..]."

Summary

- The GDPR applies by activity, not by size.
- The seven principles are the backbone, and accountability means demonstrating compliance.
- The Article 30(5) exception is narrow and often unavailable.
- Proposed amendments are not law until published.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 2, 3, 4, 5, 9 and 30. [21] European Commission, *Data protection: rules for business and organisations*. [3] See Sources for the Digital Omnibus status.

PART III · GDPR WITHOUT THE CONFUSION

CHAPTER

10

Know What You Collect and Why

A data inventory, purposes, lawful bases, minimisation, retention and access, with examples from six kinds of business.

IN THIS CHAPTER

- How to build a data inventory in an afternoon
- The six lawful bases of Article 6, and how to choose one
- How to set retention periods and control access
- Worked examples from e-commerce, consulting, hospitality, marketing, HR and SaaS

SOURCE NOTE **DATA SHIELD · D Discover and E Evidence**

Your inventory is both your discovery tool and your first piece of evidence.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the old order spreadsheet**

A small online shop exports its orders every month "just in case". After five years the exports hold more than 40,000 rows with names, addresses and phone numbers, on three laptops and a memory stick. Nobody remembers why they are kept. A laptop is stolen. The shop now has to find out what was on it.

The inventory in four columns

A data inventory does not need special software. A spreadsheet with four columns is enough: **what data, why, on what basis, and for how long**. Add where it is kept and who can access it, and you have the core of a record of processing activities (Article 30) [1]. Appendix D is a starter.

Starting your inventory

Column	Question	Example
Data	What personal data is it?	Customer name, address, order history
Purpose	Why do we have it?	To fulfil and deliver orders
Lawful basis	Which Article 6 basis applies?	Contract (6(1)(b))
Retention	How long, and why?	Six years after the order for accounting, if national law requires; then delete
Location and access	Where is it, and who can see it?	Shop platform; two named staff

The six lawful bases

Every use of personal data needs a lawful basis (Article 6(1)). There are six, and they are equal in rank. Choose the one that truly fits, record it and tell people [1].

Article 6(1): the six lawful bases

Basis	When it fits	Watch out for
(a) Consent	You offer a real choice, for example optional marketing emails	It must be freely given, specific, informed and unambiguous, and easy to withdraw [8]
(b) Contract	Processing is necessary to perform a contract with the person, or steps before entering one	"Necessary" is narrow. Extras do not count
(c) Legal obligation	The law requires it, for example tax records	Cite the law, and keep only what it needs
(d) Vital interests	Protecting someone's life	Rare in business
(e) Public task	Official functions	Mostly public bodies
(f) Legitimate interests	Your or a third party's genuine interest, balanced against the person's rights	Requires a three-part test: purpose, necessity, balancing. Document it

GOOD PRACTICE **Choose the basis before you collect**

Do not pick a lawful basis afterwards to justify what you already did. Decide, record, then tell people in your privacy notice (Chapter 11). Special-category data needs an Article 9 condition **in addition** to an Article 6 basis.

Six worked examples

Examples by type of business (all hypothetical)

Business	Data and purpose	Likely basis	Retention note
E-commerce shop	Order details to deliver goods	Contract (b); accounting records under legal obligation (c)	Keep order data as long as law requires; delete the rest
Consultancy	Client contacts and project files	Contract (b); legitimate interests (f) for follow-up	Delete when the engagement and its legal retention end
Restaurant or hotel	Bookings; guest registration where national law requires it	Contract (b); legal obligation (c)	Keep what the law requires; delete allergy notes after the stay unless needed
Marketing agency	Newsletter lists; client campaign data as processor	Consent (a) for newsletters; processor for client data under a contract	Honour unsubscribes quickly; delete client data per agreement
HR in a small firm	Payroll, contracts, absences	Contract (b) and legal obligation (c); special-category data needs an Article 9 condition	Keep as employment and tax law require
SaaS start-up	User accounts, logs, support tickets	Contract (b); legitimate interests (f) for security logs	Define log retention; delete accounts on closure

WATCH OUT **Do not guess national rules**

Retention periods, guest registration, employment record rules and marketing rules are partly set by **national law**. The examples show the type of reasoning, not the legal answer for your country. Check with your supervisory authority, for example Croatia's AZOP (https://azop.hr/) [19], or an adviser.

Minimise and control

- **Minimise.** If you do not need a field, do not collect it. Make optional fields truly optional.
- **Limit access.** Give each person access only to what their job needs.
- **Set retention.** Decide how long, record why, and schedule deletion. Appendix I provides a schedule.
- **Be consistent.** Use the same categories in your inventory, notice and retention schedule.

HYPOTHETICAL EXAMPLE **Hypothetical case study: the clean-up**

The online shop from the opening scenario spends a Saturday on its inventory. It discovers three copies of the order export, a marketing list with no record of consent and a spreadsheet of "VIP" customers with personal comments. It deletes the old exports, restricts the remaining data to the platform, asks the marketing list to re-subscribe and removes the comments. Its exposure shrinks, and the next lost laptop will matter far less.

A worked example: the legitimate interests test

Legitimate interests (Article 6(1)(f)) is the most flexible basis and the one that demands the most thought. A three-step test helps, and writing the answers down turns it into evidence. Take a hypothetical small online shop that keeps website server logs, including IP addresses, to detect attacks.

A legitimate interests assessment, in brief (hypothetical)

Step	Question	The shop's answer
1. Purpose	What is the legitimate interest?	Keeping the website secure and detecting fraud
2. Necessity	Is processing necessary, and is there a less intrusive way?	Logs are needed to spot attacks. The shop keeps only the fields it needs and no more
3. Balancing	Do the individuals' interests override?	Visitors would reasonably expect security logging. The shop keeps logs for a short, fixed period, restricts access and mentions it in the privacy notice
Result	Can the shop rely on legitimate interests?	Yes, with a 30-day retention limit and a note on file. Review annually

The 30-day period is an illustration, not a legal rule. Choose a period you can justify. Individuals can object to processing based on legitimate interests (Article 21), so be ready to consider such objections.

Common mistakes and misconceptions

Inventory myths

Misconception	Reality
"Consent is the safest basis."	It can be withdrawn at any time. Use the basis that truly fits.
"We keep everything, just in case."	Storage limitation requires a reason for each period.
"The inventory is a legal formality."	It is the map you use for security, rights requests and breach response.
"Spreadsheets count as records."	They do, if complete, current and dated.

Step by step

1. **List every place data lives** (use your Chapter 3 map).
2. **For each, fill in the four columns.**
3. **Mark special-category data** and note the Article 9 condition.
4. **Set retention and delete what is past it.**
5. **Date it and diarise a review.**

CHAPTER 10 CHECKLIST

- [ ] I have a data inventory with purpose, basis and retention for each item.
- [ ] Special-category data is flagged with an Article 9 condition.
- [ ] Legitimate-interests uses have a written balancing test.
- [ ] Retention periods are set and old data is deleted.
- [ ] Access is limited to those who need it.

WHAT TO DO TODAY **What to do today**

Open a blank spreadsheet and list ten things you collect, with a purpose and a lawful basis for each. Mark any you cannot justify.

Summary

- An inventory is a spreadsheet with data, purpose, basis and retention.
- Article 6 offers six bases. Pick the one that fits.
- Minimise collection, limit access and delete on schedule.
- National law affects retention and some sector rules.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 5, 6, 9 and 30. [8] EDPB, *Guidelines 05/2020 on consent*. [19] AZOP, Croatia.

PART III · GDPR WITHOUT THE CONFUSION

CHAPTER

11

Privacy Policies, Cookies and Customer Rights

Telling people what you do, getting cookies right, and answering requests to see, correct or delete their data.

IN THIS CHAPTER

- What a privacy notice must say, and how to write one people can read
- How cookie and tracker rules work, and how they differ from the GDPR
- The rights of individuals, and the one-month response time
- A step-by-step way to handle an access request

SOURCE NOTE **DATA SHIELD · A Account and H Handle**

Accountability includes telling people what you do. Handling includes being ready when they ask.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the Friday request**

On a Friday afternoon, a former customer emails a boutique hotel: "Please send me all the personal data you hold about me and delete it." The owner panics. The reservation system holds bookings; the accountant holds invoices; a marketing tool holds an email address; and a guest once wrote a complaint that includes a staff member's name.

Transparency: your privacy notice

Articles 12 to 14 require you to tell people, in **concise, transparent, intelligible and easily accessible form, using clear and plain language**, who you are, why you use their data, on what basis, who receives it, how long you keep it, whether it goes outside the EEA, and what rights they have, including the right to complain to a supervisory authority [1]. Write for a customer, not for a lawyer. Place the notice where people meet your business: your website footer, the checkout, the sign-up form.

- **Who you are** and how to contact you.
- **What you collect** and **why**, with the lawful basis.
- **Who you share it with**, including processors and, where relevant, transfers outside the EEA.
- **How long** you keep it.
- **Their rights**, and how to use them.
- **The right to complain** to the supervisory authority.

Cookies and trackers: a different law

Cookies and similar technologies are governed mainly by the **ePrivacy Directive** (2002/58/EC), Article 5(3), as transposed into each Member State's national law, and not by the GDPR alone [4]. In outline, storing or reading information on a person's device requires **consent**, unless it is strictly necessary to provide a service the user has requested. Where personal data is involved, the GDPR also applies, including its definition of consent. The Court of Justice has held that pre-ticked boxes do not give valid consent [28], and the EDPB has issued guidance on the technical scope of Article 5(3), which reaches beyond traditional cookies to tracking pixels and similar techniques [29].

WATCH OUT **National rules differ**

How the ePrivacy rules are applied differs by country, and regulators have different priorities. Check your national electronic communications law and your supervisory authority's cookie guidance. Do not assume that a banner from a template is compliant.

Cookie and tracker basics

Type	Needs consent?	Example
Strictly necessary	Generally no	Shopping basket, login session, security
Preferences	Usually yes, unless strictly necessary for what the user asked	Language choice remembered beyond the session
Analytics	Often yes, depending on the tool and national guidance	Visitor statistics
Advertising and tracking pixels	Yes	Social media pixel, retargeting

A good banner offers **accept and reject with equal ease**, does not set non-essential cookies before consent, records the choice and lets the user change it later. Test your own site: open it in a private window and see what loads before you click anything.

Rights of individuals

The rights in Articles 15 to 22

Right	In plain English	Article
Access	See their data and get a copy	15
Rectification	Correct inaccurate data	16
Erasure	Delete data in certain cases	17
Restriction	Pause processing in certain cases	18
Portability	Receive data in a usable format, where processing is by consent or contract and automated	20
Objection	Object to processing, including direct marketing	21
Automated decisions	Not to be subject to certain solely automated decisions	22

You must respond **without undue delay and in any event within one month** of receiving the request, which can be extended by up to two further months for complex or numerous requests, in which case you must tell the person within the first month (Article 12(3)). Information is generally provided free of charge. You may ask for proof of identity where there is reasonable doubt [1]. Rights are not absolute. Erasure, for example, does not apply where you must keep data to comply with a legal obligation. The EDPB's guidelines on the right of access explain how to handle requests [14].

Handling an access request

1. **Log it.** Record the date received. The clock starts now.
2. **Confirm identity** if there is reasonable doubt, without asking for more than you need.
3. **Search every location** in your inventory: email, systems, processors, backups where practical.
4. **Gather and review.** Redact other people's data where needed.
5. **Reply in a clear, usable form** with the information Article 15 requires, within the deadline.
6. **Record what you did.**

HYPOTHETICAL EXAMPLE **Hypothetical case study: the hotel's reply**

The hotel owner logs the request, uses her inventory to find the three systems, asks her marketing tool provider to export the email record, redacts the staff member's name from the complaint and sends a clear reply within three weeks. She deletes what she no longer needs, and explains that invoices must be kept for tax purposes. Her inventory turned a panic into a routine.

Email marketing in brief

Marketing by email is governed by the ePrivacy rules as well as the GDPR [4]. In outline, Article 13 of the ePrivacy Directive requires **prior consent** for unsolicited electronic marketing to individuals, with a limited exception where you obtained someone's email address in the course of a sale and market your own **similar** products, provided they could object at the time and can opt out easily in every message. Rules for marketing to business contacts differ by country. Separately, the GDPR gives people an absolute right to object to direct marketing (Article 21(2) and (3)): once they object, you must stop [1]. Practical rules: keep proof of consent, make unsubscribing as easy as subscribing, honour opt-outs promptly, and never buy email lists of unknown origin.

Common mistakes and misconceptions

Notice, cookie and rights myths

Misconception	Reality
"A privacy policy copied from another site will do."	A notice must describe your own processing.
"Cookie banners are optional for small sites."	Rules apply to any site that sets non-essential cookies.
"We can charge a fee for access."	Generally free, except for manifestly unfounded or excessive requests.
"Erasure means delete everything."	It is subject to legal exceptions.
"Ignoring a request makes it go away."	Individuals can complain to the supervisory authority.

CHAPTER 11 CHECKLIST

- [ ] My privacy notice describes my real processing, in plain language.
- [ ] My cookie banner does not set non-essential cookies before consent, and rejecting is as easy as accepting.
- [ ] I have a one-page process for rights requests.
- [ ] I log the date of every request.
- [ ] I have checked national cookie and marketing rules.

WHAT TO DO TODAY **What to do today**

Open your website in a private window and note which cookies load before you click anything. If any are non-essential, ask your web provider to change that.

Summary

- Tell people what you do, plainly (Articles 12 to 14).
- Cookies fall under ePrivacy rules and national law as well as the GDPR.
- Individuals have rights, and you have one month to respond.
- A good inventory makes requests routine.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 12 to 22. [4] ePrivacy Directive 2002/58/EC, Article 5(3). [8] EDPB, *Guidelines 05/2020 on consent*. [14] EDPB, *Guidelines 01/2022 on the right of access*. [28] CJEU, Case C-673/17 (1 October 2019). [29] EDPB, *Guidelines 2/2023 on technical scope of Art. 5(3) of the ePrivacy Directive*.

PART III · GDPR WITHOUT THE CONFUSION

CHAPTER

12

Processors, Suppliers and International Data Transfers

Due diligence, Article 28 contracts, sub-processors, and what to do when data leaves the European Economic Area.

IN THIS CHAPTER

- How to do due diligence on a supplier
- What Article 28 contracts must contain
- How transfers outside the EEA work: adequacy, safeguards and risk assessments
- A practical checklist for a new SaaS or AI supplier

SOURCE NOTE **DATA SHIELD · A Assess and A Account**

Every supplier is a risk you chose. Assess before you sign, and record why you decided as you did.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the new booking tool**

A small yoga studio chooses a cheap booking tool found online. It collects names, health notes and card payments. The provider is based outside Europe. The studio's owner never reads the terms. A year later a customer asks where her health notes are stored. The owner cannot say.

Due diligence in plain English

Article 28(1) requires you to use only processors that provide **sufficient guarantees** to implement appropriate technical and organisational measures [1]. For a small business that means asking sensible questions before you sign and keeping the answers. You are not auditing the provider. You are checking that your reliance on it is reasonable.

What the contract must contain

Article 28(3) requires a binding contract or other legal act that, among other things, requires the processor to: process data only on your documented instructions; ensure confidentiality; take appropriate security measures; respect the conditions for engaging sub-processors; assist you with individuals' rights, security, breach notification and impact assessments; delete or return data at the end; and make available the information needed to show compliance, including allowing audits [1]. Most reputable suppliers offer a standard data processing agreement (DPA). Read it, and check it covers these points.

Sub-processors

If your supplier engages its own suppliers (sub-processors), Article 28(2) and (4) require your authorisation, which may be general with notice of changes, and the same data protection obligations to flow down. Ask for the list and how changes are notified.

Transfers outside the EEA

Chapter V of the GDPR (Articles 44 to 49) restricts transfers of personal data to countries outside the EEA. A transfer needs a valid mechanism [1]:

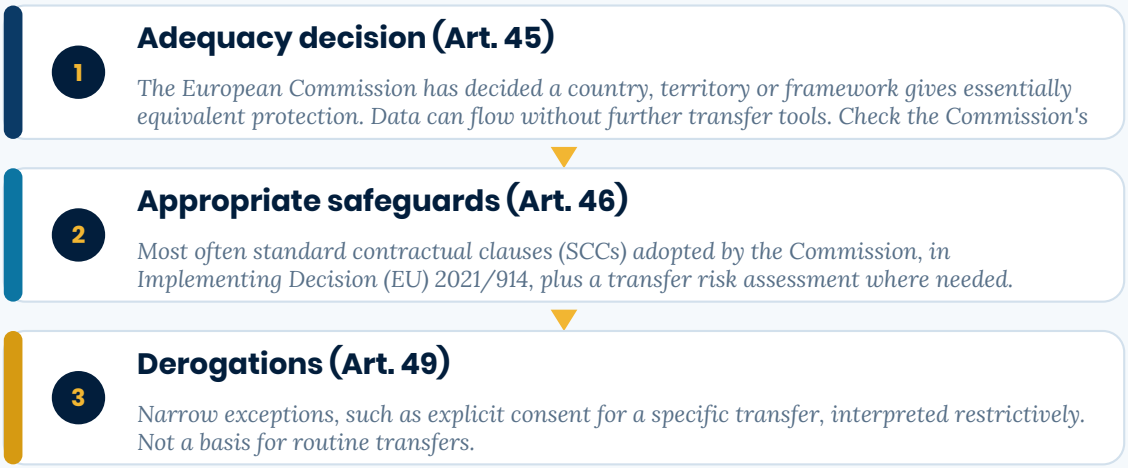


Figure 10 Three levels of transfer mechanism

For the **United States**, the Commission adopted an adequacy decision for the EU-US Data Privacy Framework (DPF) in July 2023, which covers transfers to organisations that have self-certified under it [12]. The General Court dismissed a challenge to that decision on 3 September 2025, and an appeal to the Court of Justice (Case C-703/25 P) was reported as pending at the cut-off. Check the current position, and check that your specific supplier is listed as certified, before relying on the framework.

Where you rely on SCCs, the Court of Justice's *Schrems II* judgment (Case C-311/18) requires the exporter to assess whether the destination country's law and practice allow the clauses to be effective, with supplementary measures where needed. The EDPB's Recommendations 01/2020 describe a method for this "transfer impact assessment" [13]. In practice, small businesses should ask the provider for its transfer documentation, and take advice if sensitive data is involved.

A checklist for a new SaaS or AI supplier

NEW SUPPLIER ASSESSMENT

Question	What to ask	Answer and evidence
1. Identity	Who is the legal entity, and where is it established?	
2. Role	Is it our processor, and for which purposes might it be a controller?	
3. Contract	Is there a DPA covering Article 28(3)?	
4. Security	What measures and certifications are described?	
5. Sub-processors	Is there a list, and how are changes notified?	
6. Location	Where is data stored and accessed from?	
7. Transfers	Which transfer tool applies (adequacy, SCCs, DPF certification)?	
8. Retention	How long is data kept, and how is it deleted or returned?	
9. Incidents	How quickly will you tell us about a breach?	
10. Exit	Can we export our data, and what happens at termination?	

HYPOTHETICAL EXAMPLE **Hypothetical case study: the yoga studio revisits**

The studio's owner returns to the contract. The provider, it turns out, offers a DPA and lists its sub-processors, but stores data outside the EEA under SCCs. The owner records this, updates the privacy notice, removes health notes from the tool (they were not needed) and sets a calendar reminder to review the supplier annually. The cost was an hour of reading.

When you are the processor

Many small businesses are processors for their clients: agencies, accountants, translators, IT support and freelancers handle personal data on behalf of others. As a processor, you may act only on the client's documented instructions, must keep the data confidential and secure, may use sub-processors only with the client's authorisation, must help the client meet its obligations, and must tell the client without undue delay if you become aware of a personal data breach (Articles 28 and 33(2)) [1]. Expect clients to send you a data processing agreement. Read it, check that you can actually meet it, and keep a copy. Processors also have direct obligations of their own, including security and, where Article 30(2) applies, records of processing.

Common mistakes and misconceptions

Supplier and transfer myths

Misconception	Reality
"A big brand means no checks are needed."	You remain responsible for choosing a processor with sufficient guarantees.
"Data in the cloud is not a transfer."	Storage or access from outside the EEA can be a transfer.
"SCCs solve everything."	They may need a risk assessment and supplementary measures.
"The DPF covers every US company."	Only those certified under it, and its legal position may change.
"Consent covers transfers."	Article 49 consent is narrow and unsuitable for routine use.

Step by step

1. **Identify the personal data it will handle.**
2. **Complete the checklist above.**
3. **Sign the DPA** and check the transfer mechanism.
4. **Record the decision and date.**
5. **Review annually and on any change.**

CHAPTER 12 CHECKLIST

- [ ] Every supplier that handles personal data has a DPA.
- [ ] I have a list of suppliers, with locations and transfer mechanisms.
- [ ] I have checked DPF certification for any US supplier relying on it.

- [ ] I have asked for sub-processor lists.
- [ ] I review suppliers at least once a year.

WHAT TO DO TODAY **What to do today**

List your five most important suppliers that handle personal data, and mark which have a signed DPA.

Summary

- Choose processors that offer sufficient guarantees, and sign Article 28 contracts [1].
- Know about sub-processors.
- Transfers outside the EEA need adequacy, safeguards or a narrow derogation.
- Check the current status of the EU-US framework, and your supplier's certification.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 28, 44 to 49. [11] Commission Implementing Decision (EU) 2021/914 (SCCs). [12] Commission Implementing Decision (EU) 2023/1795 (DPF); General Court Case T-553/23; appeal C-703/25 P. [13] EDPB, *Recommendations* 01/2020.

PART III · GDPR WITHOUT THE CONFUSION

CHAPTER

13

DPIAs, Privacy by Design and Accountability

When a data protection impact assessment is required, what a data protection officer does, and how to document proportionately.

IN THIS CHAPTER

- When a DPIA is required, and when it is a good idea anyway
- What privacy by design and by default mean
- When a DPO is required, and why it is not compulsory for every small business
- How to keep proportionate evidence of accountability

SOURCE NOTE **DATA SHIELD · A Assess and E Evidence**

A DPIA is a structured assessment. Documentation is the evidence that you thought it through.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the staff monitoring plan**

The owner of a 20-person call centre wants to install software that records screens, tracks keystrokes and scores employees' productivity with an AI tool. The vendor says it is "fully GDPR compliant". Before agreeing, the manager asks: "Do we need to do anything first?"

The DPIA

A **data protection impact assessment** (DPIA) is a process to identify and reduce risks to individuals before you start processing that is likely to result in a **high risk** to their rights and freedoms (Article 35(1)). Article 35(3) lists three situations where one is required: systematic and extensive evaluation of personal aspects based on automated processing, including profiling, on which significant decisions are based; large-scale processing of special-category or criminal data; and systematic monitoring of a publicly accessible area on a large scale [1]. Supervisory authorities publish lists of other processing that needs a DPIA (Article 35(4)), so check your national list.

The Article 29 Working Party, whose guidelines the EDPB endorsed, set out nine criteria to help decide, including evaluation or scoring, automated decisions, systematic monitoring, sensitive data, large scale, matching data sets, vulnerable individuals, innovative technology and processing that blocks people from exercising rights. As a rule of thumb, **two or more criteria suggest a DPIA is likely needed** [9]. If a DPIA shows a high risk that you cannot mitigate, Article 36 requires consulting the supervisory authority before you proceed.

GOOD PRACTICE **A DPIA is useful even when it is optional**

A one-page assessment of a new tool, covering what data, why, who sees it, what could go wrong and how you will reduce it, is a good habit for any significant change. It is also evidence of accountability.

A simple DPIA screening

Question	If yes
Does it evaluate or score people, or monitor them systematically?	Strong signal for a DPIA
Does it involve special-category or criminal data on a large scale?	Strong signal
Does it use new technology, including AI, in a way that could affect people significantly?	Consider a DPIA
Does it involve vulnerable people, such as children or employees?	Consider a DPIA
Is it likely to be on your supervisory authority's list?	Check the list

Privacy by design and by default

Article 25 requires controllers to implement appropriate measures, **at the time of choosing the means and at the time of processing**, to put data protection principles into practice, and to ensure that by default only the personal data necessary for each purpose is processed [1][10]. In practice: choose tools with privacy-friendly settings, switch off unnecessary data collection, collect fewer fields, limit access by default and delete on schedule.

The data protection officer

Articles 37 to 39 provide for a **data protection officer** (DPO) who advises on compliance, monitors it and cooperates with the supervisory authority. Appointment is **compulsory only** where: the processing is carried out by a public authority; the core activities require **regular and systematic monitoring of individuals on a large scale**; or the core activities involve **large-scale processing of special-category or criminal data** (Article 37(1)) [1]. Many small businesses are not in these categories, although national law can add cases. You may appoint a DPO voluntarily, or use an external one. If you do appoint one, publish the contact details and notify the supervisory authority. A DPO must be independent and not be given instructions about the tasks.

> WATCH OUT **Do not use the title casually**
>
> If you appoint a "DPO" the law attaches duties and protections to the role. If you only need someone responsible for privacy day to day, call them a privacy lead or coordinator.

Accountability in proportion

Articles 5(2) and 24 require you to be able to demonstrate compliance, taking into account nature, scope, context and risks. A small business can do this with a handful of documents: an inventory, a privacy notice, supplier DPAs, a security measures summary, a breach log, a rights-request log, a short policy and dated DPIAs where needed. Keep them in one folder and review annually.

> HYPOTHETICAL EXAMPLE **Hypothetical case study: the monitoring plan**
>
> The call-centre manager screens the plan. It meets several of the nine criteria: systematic monitoring, evaluation and scoring, vulnerable individuals (employees depend on their employer) and new technology. A DPIA is very likely required. The manager drafts one, reduces the scope (no keystroke logging, no scoring), tells staff openly and consults employees' representatives as national labour law requires. She keeps the assessment on file. The vendor's "compliant" label was not a substitute.

AI, hiring and staff monitoring

The risks rise sharply when AI is used to make or support decisions about people. Using AI to rank job applicants, score performance or monitor staff engages Article 22 (automated decisions) and the transparency and fairness principles, and usually calls for a DPIA. The EU AI Act treats AI used for employment purposes, such as recruitment and worker evaluation, as **high risk** under Annex III, with demanding obligations that, as reported, were postponed to 2 December 2027 by the 2026 amendment [2][3]. The Act also prohibits certain practices, including (with limited exceptions) inferring emotions of people in the workplace [2]. National employment law and works councils often add consultation and notice duties. If you plan any of this, take specialist advice first.

Common mistakes and misconceptions

DPIA and DPO myths

Misconception	Reality
"A DPIA is only for big projects."	It depends on risk, not size.
"Our vendor did one, so we do not need one."	The controller is responsible for its own use.
"Every business needs a DPO."	Only in the Article 37(1) situations, plus any added by national law.
"Documents are for regulators only."	They help you run the business and answer customers.

Step by step

1. **Describe the processing:** what, why, who, how long.
2. **Check necessity and proportionality.**
3. **List the risks to individuals**, not just to the business.
4. **Choose measures** to reduce each.
5. **Record the outcome**, including residual risk, and review it.

CHAPTER 13 CHECKLIST

- [ ] I screen new tools and projects for DPIA need.
- [ ] I have checked my supervisory authority's DPIA list.
- [ ] I know whether a DPO is required in my situation.
- [ ] My documents are in one place, dated and reviewed.
- [ ] I have switched off unnecessary data collection by default.

WHAT TO DO TODAY **What to do today**

Take the next tool or project you plan to adopt and answer the five screening questions above. Write the answers down.

Summary

- A DPIA is required for likely high-risk processing and useful for other significant changes.
- Privacy by design and default means collecting less and protecting more from the start.
- A DPO is compulsory only in specific cases.
- Accountability needs proportionate, dated documentation.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 24, 25, 35 to 39. [9] Article 29 Working Party, *Guidelines on DPIA (WP248 rev.01)*, endorsed by the EDPB. [10] EDPB, *Guidelines 4/2019 on Article 25*.



PART

IV

Building Your Digital Defense

A proportionate security baseline, a way to manage suppliers, a calm breach playbook and a recovery plan.

PART IV · BUILDING YOUR DIGITAL DEFENSE

CHAPTER

14

A Cybersecurity Baseline for Small Businesses

Ten practical controls that cover the most common routes in, drawn from ENISA, NIST and other recognised guidance.

IN THIS CHAPTER

- Ten controls that give the most protection for the least effort
- How each control relates to Article 32 and to recognised frameworks
- What "appropriate" means for a small business
- A one-page baseline you can adopt this month

SOURCE NOTE **DATA SHIELD · S Safeguard and T Tighten**

Safeguarding is the core of this chapter: protecting accounts, systems, data and people. Tightening means closing loose settings.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the unpatched router**

A small dental practice has a router installed years ago and never updated. Its admin password is still the factory default. One night, a scan finds it from the internet. By morning the practice's network is slow and strange pop-ups appear. The practice management software holds patient records.

What "appropriate" means

Article 32 of the GDPR requires controllers and processors to implement **appropriate technical and organisational measures** to ensure a level of security appropriate to the risk, taking into account the state of the art, the cost of implementation and the nature, scope, context and purposes of processing. It lists examples: pseudonymisation and encryption; the ability to ensure ongoing confidentiality, integrity, availability and resilience; the ability to restore availability after an incident; and regular testing and evaluation [1]. The law does not prescribe particular tools. For a small business, "appropriate" means covering the common risks sensibly, and being able to explain your choices.

Useful voluntary guidance includes ENISA's cybersecurity guide for SMEs, which sets out twelve practical steps [16], and the NIST Cybersecurity Framework 2.0, which organises security around six functions: Govern, Identify, Protect, Detect, Respond and Recover [17]. These are **voluntary frameworks**, not legal requirements, but they offer a recognised vocabulary and structure.

Ten controls

The baseline

Control	What to do	Why it matters
1. Multifactor authentication (MFA)	Turn it on for email, banking, cloud, admin and remote access. Prefer app or hardware keys over text messages where possible.	Stops most account takeovers that start with a stolen password
2. Password manager and unique passwords	Use a manager; one unique password per account; long passphrases	Prevents one leak opening many doors
3. Updates and patching	Turn on automatic updates for systems, apps, browsers, routers and plug-ins; remove software you no longer use	Closes known holes
4. Endpoint protection	Use reputable security software on every laptop and server; keep it on	Catches common malware
5. Secure Wi-Fi and remote access	Change default passwords; use strong encryption; separate guest Wi-Fi; use a trusted VPN or secure access for remote work	Limits exposure from networks
6. Encryption where appropriate	Turn on full-disk encryption on laptops and phones; encrypt backups and sensitive files	Protects data if a device is lost
7. Least privilege	Give people only the access they need; separate admin and everyday accounts	Limits the damage of one compromised account
8. Secure cloud configuration	Check sharing settings; no "anyone with the link" for sensitive files; review who has access	Prevents accidental exposure
9. Tested backups and recovery plan	Keep backups that cannot be altered from your normal systems; test restoring	Gets you back after ransomware or loss
10. Training and offboarding	Short regular training; remove access the day someone leaves	Handles the human factor

IN PLAIN ENGLISH **In plain English**

Patching means installing updates that fix security flaws. **Endpoint** means any device people use: laptops, phones, tablets. **Least privilege** means giving each person the smallest access that lets them do their job.

Where the guidance comes from

ENISA's SME guide covers topics such as management responsibility, staff training, third-party management, incident response, secure devices and networks, backups and cloud security [16]. NIST's framework offers a similar spread under its six functions and provides quick-start guides and profiles on its website [17]. For authentication details, NIST publishes digital identity guidelines in its SP 800-63 series, whose recommendations on long passphrases and on not forcing frequent arbitrary password changes are widely followed [18]. ISO/IEC 27001 is a voluntary international standard for information security management that some customers may ask about, but formal certification is not required to follow good practice [31].

HYPOTHETICAL EXAMPLE **Hypothetical case study: the dental practice responds**

After the incident, the practice replaced the router, changed every default password, enabled automatic updates, turned on MFA for the practice software, separated guest Wi-Fi from the clinical network and tested restoring last night's backup. The work took two days and a modest budget. The practice also recorded the measures in a one-page security summary, which later helped when a supplier asked about its security.

If your budget is tiny: a priority order

Security spending should follow risk. If you can do only five things, do these, in this order. Most cost little or nothing:

1. **Multifactor authentication** on email, banking and cloud. Usually free.
2. **A password manager.** Low cost per user.
3. **Automatic updates** everywhere, including the router. Free.
4. **Tested backups,** with one copy offline. Low cost.
5. **A call-back rule** for payments and a short training session. Free.

After these, add device encryption, access reviews and a one-page security summary. Paid tools matter less than habits.

Common mistakes and misconceptions

Security myths

Misconception	Reality
"Antivirus is enough."	It is one control of ten.
"Backups are done, so we are safe."	Untested backups often fail, and backups connected to the network can be encrypted too.
"We use text-message codes, so MFA is solved."	Better than nothing, but app or hardware methods resist more attacks.
"Updates can wait."	Known flaws are exploited quickly.
"Security is a product we buy."	It is a set of habits plus tools.

Step by step: adopt the baseline

1. **Week 1.** Turn on MFA on email and finance. Install a password manager.
2. **Week 2.** Turn on automatic updates; remove old software and accounts. Change default passwords on routers and devices.
3. **Week 3.** Encrypt laptops and phones. Review cloud sharing settings. Set up or test backups.
4. **Week 4.** Write a one-page summary of your measures. Brief the team. Add offboarding to your leaving checklist.

CHAPTER 14 CHECKLIST

- [ ] MFA is on for email, banking, cloud and admin accounts.
- [ ] Everyone uses a password manager.
- [ ] Automatic updates are on, including routers and plug-ins.
- [ ] Laptops and phones are encrypted and locked.
- [ ] Sharing links are reviewed; nothing sensitive is open to anyone.
- [ ] Backups are tested, with one copy offline or immutable.
- [ ] Access is least-privilege, and leavers are removed on the day.

WHAT TO DO TODAY **What to do today**

Turn on MFA for your email account. If you finish, install a password manager.

Summary

- Article 32 requires security appropriate to the risk, with no fixed list [1].
- Ten baseline controls cover the most common routes.
- ENISA and NIST are recognised voluntary sources [16][17].
- Document what you do.

SOURCE NOTE **Key sources**

[1] GDPR, Article 32. [16] ENISA, *Cybersecurity guide for SMEs*. [17] NIST, *Cybersecurity Framework 2.0*. [18] NIST SP 800-63 series. [31] ISO/IEC 27001.

PART IV · BUILDING YOUR DIGITAL DEFENSE

CHAPTER

15

Vendor and Supply-Chain Risk

How to assess suppliers by what data they touch and how critical they are, with a reusable checklist.

IN THIS CHAPTER

- Why your suppliers' weaknesses become yours
- A three-question way to tier vendors
- What to assess, from security practice to incident notification
- A reusable vendor assessment checklist

SOURCE NOTE **DATA SHIELD · A Assess and E Evidence**

Assess suppliers in proportion to the data they touch and how much you depend on them, and keep the evidence.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the compromised plug-in vendor**

A small online bookshop relies on a third-party plug-in for its newsletter sign-up. The plug-in vendor, a one-person company, has its own account taken over. A malicious update is pushed to its customers, including the bookshop, whose sign-up form begins sending visitors' email addresses to an unknown server.

Why supply chains matter

Your business depends on other businesses' software and services. A weakness in any of them can reach you. ENISA's SME guidance lists third-party management as one of its twelve steps [16]. Under the GDPR, Article 28 makes you responsible for choosing processors with sufficient guarantees, and Article 32 applies to your whole processing chain [1]. If you are in scope of the NIS2 Directive, which applies to certain sectors and size thresholds, supply-chain security is an explicit duty [5]. Most micro and small businesses are outside NIS2's direct scope, but may supply to those who are in scope and be asked for assurances.

Tier your vendors with three questions

Vendor tiers

Question	Why it matters
What data does it access? Personal, financial, special-category, secrets?	More sensitive data means more assessment.
How important is it to the business? Could we operate without it for a week?	Critical suppliers need exit plans.
How much access does it have? Read-only, admin, network connection?	Broad access raises risk.

Combine the answers into three tiers: **high** (sensitive data or critical function), **medium** and **low**. Assess high-tier vendors in detail, medium vendors briefly, and low vendors by exception. Keep it proportionate.

What to assess

VENDOR ASSESSMENT CHECKLIST

Area	Question	Answer and evidence
Data	What data will the vendor access or hold, and why?	
Contract	Is there a DPA and a service agreement with clear obligations?	
Security	Which measures or certifications are described (for example ISO/IEC 27001)?	
Access	Does the vendor access our systems? With what privileges?	
Sub-suppliers	Who else is involved, and where?	
Transfers	Is data transferred outside the EEA, and under which mechanism?	
Incidents	Does the contract require prompt notification of incidents, and within what time?	
Continuity	What happens if the service fails? Do we have an exit or backup route?	
Exit	Can we get our data back, and is it deleted afterwards?	
Review	When will we reassess?	

GOOD PRACTICE **Incident notification matters most**

Under Article 33(2), a processor must notify the controller **without undue delay** after becoming aware of a personal data breach [1]. Check that your contracts say something concrete, such as notification within 24 or 48 hours, because your own 72-hour clock, where Article 33 applies, may start when **you** become aware.

HYPOTHETICAL EXAMPLE **Hypothetical case study: the bookshop's response**

The bookshop removes the plug-in, replaces it with a better-supported alternative and checks its logs for the period involved. It notes that it is a controller for the email addresses, assesses the risk to subscribers, concludes after advice that notification to the supervisory authority is required, and writes to subscribers in plain language. It then builds a vendor list with tiers, a DPA check for each tier-one supplier and a rule: no new plug-in without an owner and a review date.

What to ask for in the contract

Contracts are where good intentions become obligations. For your high-tier vendors, look for: a clear description of the service and the data involved; security commitments you can point to; a duty to notify you of incidents within a stated time; a list of sub-processors and notice of changes; your right to receive information that shows compliance and, for critical suppliers, to audit or review assurance reports; help with your own duties, such as individuals' rights requests; return or deletion of data at the end; and help moving to another supplier if the relationship ends. Small suppliers rarely negotiate, but a short written addendum or a published standard DPA is often enough. Where a supplier refuses basic terms for a service that handles sensitive data, treat that as information.

The one-person vendor problem

Many useful tools are built by very small companies or individual developers. They can be excellent, and they can also disappear, be sold or be compromised, as the bookshop story shows. For plug-ins, extensions and browser add-ons, ask: who maintains this, when was it last updated, what access does it need, and what happens if it stops? Prefer tools with a visible maintenance record, grant the narrowest permissions, and remove anything you no longer use.

Common mistakes and misconceptions

Vendor-risk myths

Misconception	Reality
"A small plug-in cannot matter."	It can run on every page of your site.
"The vendor is responsible, not us."	You remain responsible for your own processing and choice of processors.
"We checked at purchase, that is enough."	Vendors change. Review periodically.
"Certification equals safe."	It is evidence, not a guarantee.

Step by step

1. **List all vendors** from your invoices, app stores and accounts.
2. **Tier them** with the three questions.
3. **Assess the high tier** with the checklist.
4. **Fix contract gaps**, especially incident notification and sub-processors.
5. **Schedule annual reviews.**

CHAPTER 15 CHECKLIST

- [ ] I have a list of vendors with tiers.
- [ ] High-tier vendors have been assessed and the evidence is saved.
- [ ] Contracts state incident notification times.
- [ ] I have an exit plan for critical suppliers.
- [ ] I review vendors annually.

WHAT TO DO TODAY **What to do today**

Open your last three months of invoices and card statements. List every software or service you pay for. That is your starting vendor list.

Summary

- Your suppliers' weaknesses can become yours.
- Tier vendors by data, importance and access.
- Check contracts for incident notification and sub-processors.
- Review regularly.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 28, 32 and 33. [5] NIS2 Directive (EU) 2022/2555. [16] ENISA, *Cybersecurity guide for SMEs*.

PART IV · BUILDING YOUR DIGITAL DEFENSE

CHAPTER

16

Your First 72 Hours After a Data Breach

A calm playbook: recognise, contain, assess, decide on notification, communicate, recover and learn.

IN THIS CHAPTER

- The difference between a cybersecurity incident and a personal data breach
- A ten-step incident response playbook
- What the 72-hour rule in Article 33 actually says, and what it does not
- When individuals must be told under Article 34
- A ready-to-use incident log

SOURCE NOTE **DATA SHIELD · H Handle and L Learn**

Handling an incident well is mostly preparation. Learning from it is what stops the next one.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: Friday, 17:40**

The owner of a six-person dental supplies firm receives a message from a customer: "I just got an email from you with someone else's order list attached." The owner checks the sent folder and finds nothing. Then she sees a forwarding rule she did not create. Her email account has been used by someone else for days.

Incident or breach?

A **cybersecurity incident** is any event that compromises the security of systems or data, such as ransomware, a lost laptop or a compromised account. A **personal data breach** is a narrower legal term: a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data (Article 4(12)) [1]. Many incidents are not personal data breaches, for example an attack that blocks a website but touches no personal data. Many personal data breaches are not "cyberattacks", for example sending an email to the wrong person. The EDPB's guidelines distinguish breaches of confidentiality, integrity and availability [7].

The 72-hour rule: exactly what it says

WHAT THE LAW SAYS **What the law says**

Article 33(1): in the case of a personal data breach, the controller shall **without undue delay and, where feasible, not later than 72 hours after having become aware of it**, notify the supervisory authority, **unless the breach is unlikely to result in a risk to the rights and freedoms of natural persons**. If notification is not made within 72 hours, it must be accompanied by reasons for the delay. Article 33(5) requires you to **document every personal data breach**, including facts, effects and remedial action, whether or not you notify [1].

Four points are often misunderstood:

- **It applies to personal data breaches, not to every cyber incident.**
- **It is not an automatic duty to notify.** If the breach is unlikely to result in a risk, you document and do not notify.

- **The clock starts when you become aware**, which the EDPB describes as when the controller has a reasonable degree of certainty that a security incident has occurred that has led to personal data being compromised [7]. Brief investigation is allowed, but do not wait idly.
- **A processor must tell the controller without undue delay** (Article 33(2)), and the controller's clock runs from awareness.

> WATCH OUT **Other deadlines can apply**
>
> Regulatory notification under the GDPR is separate from contractual duties to clients, insurer conditions, sector rules, and national or NIS2 incident reporting where you are in scope [5]. Check each one. Their clocks and recipients may differ.

Ten steps

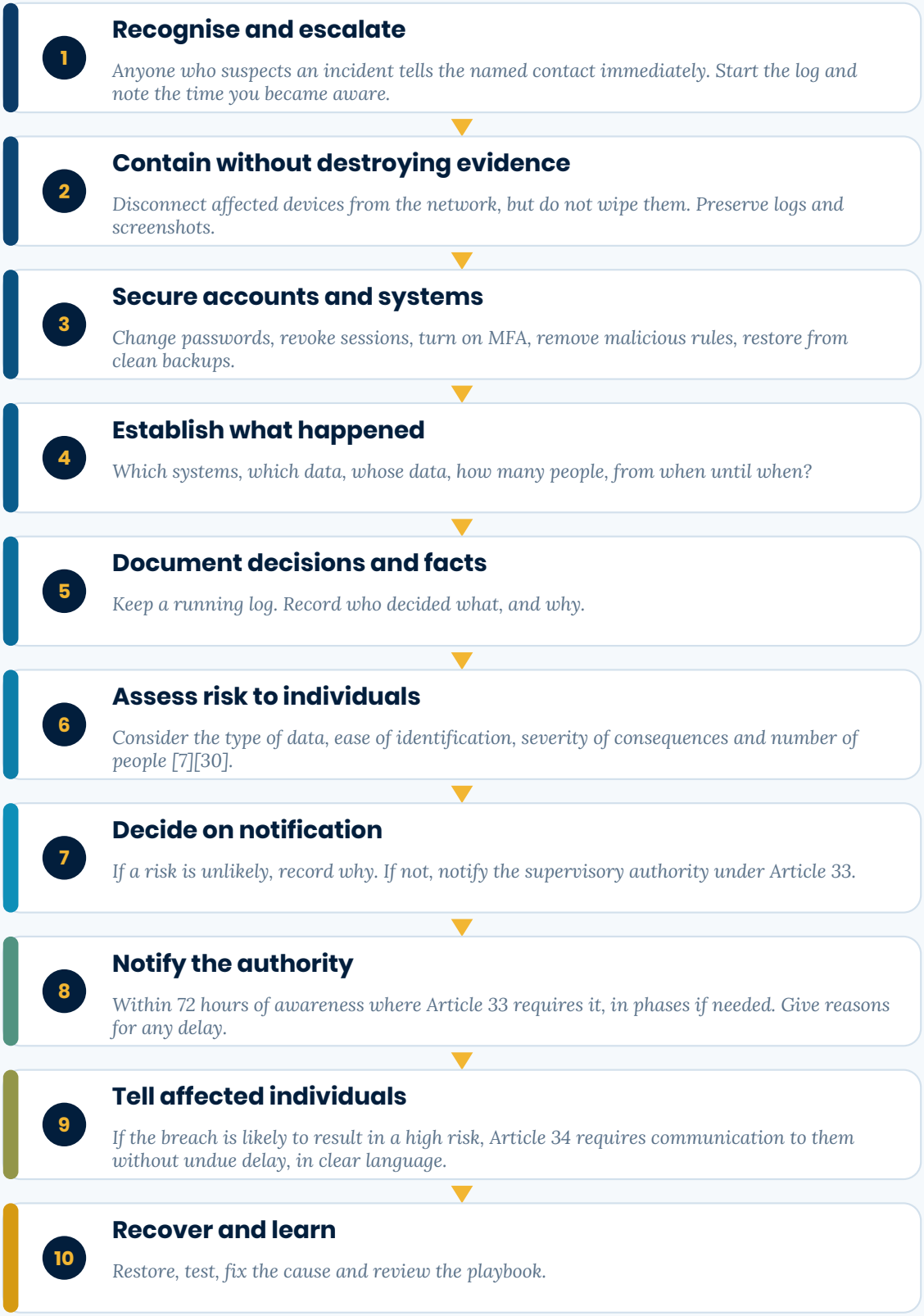


Figure 11 The incident response playbook

IN PLAIN ENGLISH **In plain English**

Article 34 sets a **higher bar** than Article 33. You notify the authority if there is a **risk**, and you tell individuals when the risk is **high**. Article 34(3) lists exceptions, for example where data was effectively encrypted or you have taken measures that mean a high risk is no longer likely [1].

What to tell the authority

Article 33(3) says the notification must describe the nature of the breach, including categories and approximate numbers of individuals and records affected; give the contact details of the DPO or another contact point; describe the likely consequences; and describe the measures taken or proposed. If you cannot provide everything at once, you may provide the information in phases without undue further delay [1]. Find the right authority and its online form in advance. In Croatia, for example, AZOP has a page for reporting personal data breaches [19]. The EDPB lists all national authorities on its website [20].

HYPOTHETICAL EXAMPLE **Hypothetical case study: the forwarding rule**

The owner acts at once. She removes the rule, changes her password, signs out all sessions, turns on MFA and notes the time. Over the weekend she establishes that the attacker read mail and forwarded messages containing customer orders, names and addresses of about 300 people, with no payment or special-category data. After taking advice she decides there is a risk, notifies the supervisory authority on Sunday, within 72 hours of becoming aware, tells her customers in plain language and records every step. Her prepared log and contact list saved hours.

Incident log template

TEMPLATE

Data breach incident log

Complete as soon as an incident is suspected. Keep the original, even if you decide not to notify. This is a starting point and not legal advice.

Reference, date and time reported, and by whom

Date and time you became aware (this starts the 72-hour clock)

What happened, in plain words

Systems, accounts and devices affected

Types of personal data involved, and special categories

Approximate number of people and records

Likely consequences for individuals

Containment steps taken, with times

Risk assessment: is a risk to individuals likely? Why or why not?

Decision on notifying the supervisory authority, who decided, and when

Decision on informing individuals (high risk?), and when

Other notifications (clients, insurer, police, sector regulator)

Remedial actions and prevention

Ransomware and payment demands

Ransomware encrypts your files and demands payment. If it happens, **isolate** affected machines from the network at once, but do not wipe them, and call for help before anything else. Paying is a business decision with no guarantee that you will get your data back, may encourage further attacks and, depending on who is paid, could raise legal issues, so take advice and report the incident to the police and the relevant authority. If personal data was accessible to the attacker, it may be a personal data breach, so follow the steps above. A tested, offline backup is the best protection, because it can remove the pressure to pay.

What to tell affected individuals

When Article 34 applies, the communication must be in **clear and plain language** and describe the nature of the breach, give the name and contact details of a contact point, describe the likely consequences and describe the measures taken or proposed (Article 34(2)) [1]. Good practice is to add practical advice: change passwords, watch for suspicious messages, contact the bank. Be honest and specific, apologise sincerely, and avoid defensive or technical language.

Common mistakes and misconceptions

Breach myths

Misconception	Reality
"Every incident must be reported in 72 hours."	Only personal data breaches likely to result in a risk, under Article 33.
"If we do not notify, we do not need to record."	Article 33(5) requires documenting every breach.
"We should wait until we know everything."	You can notify in phases.
"Deleting evidence limits the damage."	It can hamper investigation and compliance.
"Telling customers is always required."	Only for high risk, with exceptions.

Step by step: prepare before it happens

1. **Name an incident lead and a deputy.**
2. **Write down contacts:** supervisory authority form, adviser, IT help, insurer, key clients.
3. **Print the log** and the playbook.
4. **Rehearse** a scenario for 30 minutes once a year.
5. **Check contracts** for notification duties.

CHAPTER 16 CHECKLIST

- [ ] I know the difference between an incident and a personal data breach.
- [ ] I know who the incident lead is.
- [ ] I have found my supervisory authority's notification form.
- [ ] I have an incident log ready.
- [ ] I have practised the first hour.

WHAT TO DO TODAY **What to do today**

Find your supervisory authority's breach notification page and save the link in your incident file. Add your incident lead's mobile number.

Summary

- Not every incident is a personal data breach.
- Article 33: notify the authority within 72 hours of awareness, where feasible, unless a risk is unlikely [1].
- Article 34: tell individuals when there is a high risk.
- Document every breach.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 4(12), 33, 34. [5] NIS2. [7] EDPB, *Guidelines 9/2022*. [19] AZOP. [20] EDPB, list of members. [30] EDPB, *Guidelines 01/2021 on examples regarding personal data breach notification.*



PART IV · BUILDING YOUR DIGITAL DEFENSE

CHAPTER

17

Business Continuity and Recovery

Backups, recovery testing, roles, emergency contacts and realistic priorities for getting back to work.

IN THIS CHAPTER

- The difference between a backup and a recovery plan
- How to set realistic recovery priorities
- A simple continuity plan on two pages
- How to test recovery without disruption

SOURCE NOTE **DATA SHIELD · H Handle and I Improve**

Handling includes being able to carry on. Improving means testing the plan and fixing what breaks.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the flooded office**

A small accountancy firm's office floods on a Thursday in February. Laptops are lost, the paper files are soaked and the server is dead. The firm has a cloud backup, but nobody has tested restoring it, nobody knows which password unlocks it, and the clients' filing deadline is in eight days.

Backup is not recovery

A backup is a copy. **Recovery** is getting back to work. Article 32(1)(c) refers to the ability to restore the availability of and access to personal data in a timely manner after a physical or technical incident [1]. The practical test is simple: **can you restore the files you need, in the time you can afford, with the passwords you have?** Follow the widely used rule of three copies, on two kinds of storage, with one kept offline or immutable, and test it.

Prioritise realistically

A simple recovery priority table

Priority	What	Target to get back (your decision)
1. Immediate	Email, phones, payment access, customer communication	Hours
2. Urgent	Order systems, accounting, project files	One to two days
3. Important	Archives, marketing tools, internal wikis	Days to weeks

Two terms are useful. **Recovery time objective** (RTO) is how long you can afford to be without something. **Recovery point objective** (RPO) is how much recent work you can afford to lose. They are your own business decisions, not legal numbers.

A two-page continuity plan

- **Roles.** Incident lead, deputy, who talks to customers, who talks to suppliers.
- **Contacts.** Phone numbers on paper and on personal phones: staff, IT help, bank, insurer, key suppliers.
- **Systems and priorities.** The table above, with passwords' location noted, not the passwords themselves.
- **Workarounds.** How you invoice, answer calls and take orders without your main systems.
- **Communications.** What you will tell customers, in a short template.
- **Recovery steps.** Who restores what, in which order.

> HYPOTHETICAL EXAMPLE **Hypothetical case study: the firm recovers**
>
> After the flood, the accountancy firm moves to cloud-based tools with sign-in from any device, keeps an offline copy of key files, writes a two-page plan, practises restoring a single client folder every quarter and stores contacts on paper in two places. When a laptop is stolen eight months later, the firm is working again within a day.

Backups that survive ransomware

Attackers often look for backups first. Keep at least one copy that **cannot be changed or deleted from your normal accounts**: an offline drive stored away from the office, or cloud storage with immutable or versioned copies and a separate login with its own MFA. Do not leave a backup drive permanently plugged in. Keep a record of where backups are, how to restore them and who can do it, in your paper contact list.

Who does what in a disruption

In a crisis the first problem is rarely technical. It is that nobody knows who decides. Assign four roles, even if one person holds several: an **incident lead** who makes decisions and keeps the log, a **technical contact** who restores systems or manages the external help, a **communications contact** who speaks to customers, staff and suppliers, and a **deputy** for each. Write down who can authorise a payment, who can approve a notification and who talks to the supervisory authority. Put the names and mobile numbers on paper.

Three drills worth doing

1. **The restore drill (quarterly).** Restore one real client folder from backup to a different location and time it.
2. **The lock-out drill (twice a year).** Imagine your main email is unavailable for two days. How do you reach customers, staff and the bank?
3. **The tabletop drill (yearly).** Spend thirty minutes walking through a scenario from this book, noting every point where someone says "I am not sure who does that".

Each drill produces a short list of fixes. Record them in your risk register, and tick them off. That list is the best evidence that your plan is alive.

Common mistakes and misconceptions

Continuity myths

Misconception	Reality
"We use the cloud, so we are backed up."	Sync is not backup. Deleting a file may delete it everywhere.
"Recovery is IT's job."	Business decisions on priorities are yours.
"A plan in a drawer is enough."	Test it and keep copies where you can reach them.
"We will remember what to do."	In a crisis, people forget. Write it down.

Step by step

1. **List the five things you cannot work without.**
2. **Decide how long you can be without each.**
3. **Check how each is backed up, and restore one.**
4. **Write the two-page plan.**
5. **Share it and set a test date.**

CHAPTER 17 CHECKLIST

- [ ] I follow three copies, two media, one offline or immutable.
- [ ] I have restored a file from backup this year.
- [ ] Recovery priorities are written down.
- [ ] Contacts are on paper and on personal phones.
- [ ] There is a two-page plan, and people know where it is.

WHAT TO DO TODAY **What to do today**

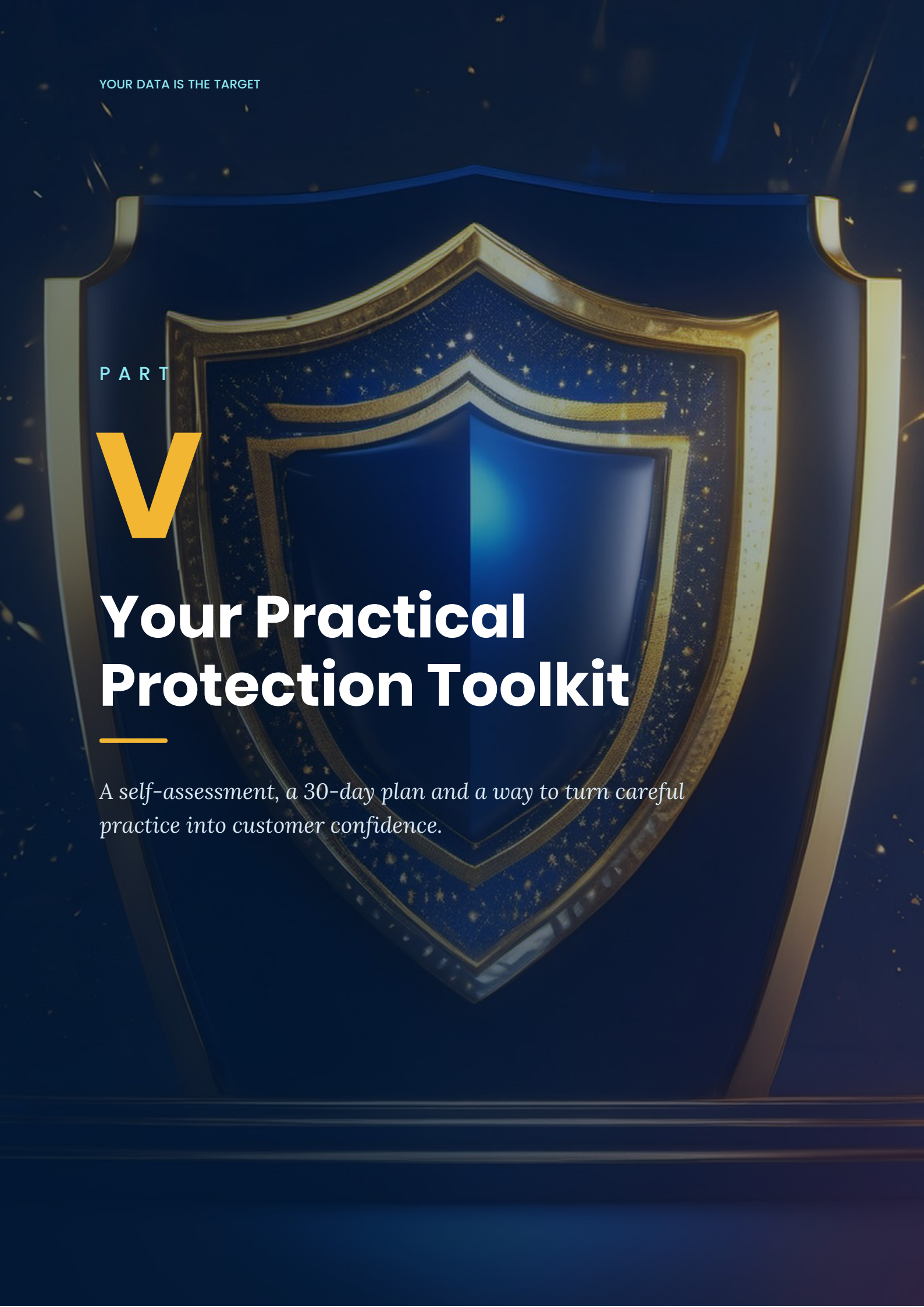
Restore one file from your backup to a different folder, and check that you can open it. Note how long it took.

Summary

- Backup is a copy. Recovery is getting back to work.
- Set priorities and targets that fit your business.
- Keep the plan short, written and tested.
- Article 32 includes the ability to restore availability [1].

SOURCE NOTE **Key sources**

[1] GDPR, Article 32(1)(c). [16] ENISA, *Cybersecurity guide for SMEs* (backups and incident response). [17] NIST, *Cybersecurity Framework* 2.0 (Respond, Recover).



PART

V

Your Practical Protection Toolkit

A self-assessment, a 30-day plan and a way to turn careful practice into customer confidence.

PART V · YOUR PRACTICAL PROTECTION TOOLKIT

CHAPTER

18

The Small Business Privacy and Security Audit

A structured self-assessment across eight areas, with a score you can repeat.

IN THIS CHAPTER

- Eight areas to review: governance, personal data, AI use, vendors, access, website, incidents and people
- A scoring method that shows your strongest and weakest areas
- How to turn results into a risk register
- How to repeat the audit to show progress

SOURCE NOTE **DATA SHIELD · A Assess and E Evidence**

An audit is assessment made visible. Dated results are also evidence that you review your own practice.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the first honest score**

The owner of a nine-person events agency sits down for ninety minutes with a coffee and the audit below. She expected to score well, because she "had a privacy policy". She scores 29 out of 80. The result is uncomfortable, and useful: it shows her exactly which five things to fix first.

This is a **self-assessment**, not a formal audit or a compliance assessment. It cannot tell you whether you comply with the law. It helps you see where you stand, spot gaps and set priorities. Score each statement: **0** if it is not true, **1** if it is partly true, **2** if it is fully true and you could show evidence. Add up each area, then the total.

Area 1: Governance

AREA	YOUR SCORE	OUT OF
1. A named person is responsible for privacy and security		**2**
2. We have written down our role as controller or processor		**2**
3. We have a short privacy and security policy that staff have read		**2**
4. Decisions about tools and data are recorded with dates		**2**
5. We review our practices at least once a year		**2**
TOTAL SCORE		**10**

Area 2: Personal data

AREA	YOUR SCORE	OUT OF
1. We have a data inventory or record of processing		2
2. Each use of personal data has a recorded lawful basis		2
3. Retention periods are set and old data is deleted		2
4. Special-category data is identified and specially protected		2
5. We can respond to a rights request within one month		2
TOTAL SCORE		**10**

Area 3: AI use

AREA	YOUR SCORE	OUT OF
1. We know which AI tools staff use for work		2
2. We have a never-paste list that staff know		2
3. AI tools used with personal data have a reviewed contract		2
4. A person checks AI output before it is used		2
5. We have thought about automated decisions affecting people		2
TOTAL SCORE		**10**

Area 4: Vendors

AREA	YOUR SCORE	OUT OF
1. We have a list of suppliers that handle personal data		2
2. Each has a data processing agreement where required		2
3. We know where each stores or transfers data		2
4. Contracts say how quickly they must report incidents		2
5. We review key suppliers at least yearly		2
TOTAL SCORE		10

Area 5: Access control

AREA	YOUR SCORE	OUT OF
1. MFA is on for email, banking, cloud and admin accounts		2
2. Everyone uses a password manager and unique passwords		2
3. People have only the access they need		2
4. Leavers lose access on their last day		2
5. Devices are encrypted, locked and updated		2
TOTAL SCORE		10

Area 6: Website and marketing

AREA	YOUR SCORE	OUT OF
1. Our privacy notice describes what we really do		2
2. Non-essential cookies load only after consent		2
3. Rejecting cookies is as easy as accepting		2
4. Marketing emails have a valid basis and an easy opt-out		2
5. Forms collect only the data we need		2
TOTAL SCORE		**10**

Area 7: Incident response

AREA	YOUR SCORE	OUT OF
1. We have a named incident lead and deputy		2
2. We know the difference between an incident and a personal data breach		2
3. We have an incident log ready		2
4. We know how to notify our supervisory authority		2
5. Backups are tested and a recovery plan exists		2
TOTAL SCORE		**10**

Area 8: People and awareness

AREA	YOUR SCORE	OUT OF
1. Staff have had security and privacy training this year		2
2. Staff know how to spot phishing and impersonation		2
3. Payment changes require a call-back		2
4. Staff know it is safe to report mistakes		2
5. New starters are briefed in their first week		2
TOTAL SCORE		10

0 to 30	31 to 55	56 to 80
Needs attention	**Developing**	**Established**
Start with the 30-day plan in Chapter 19. Fix the "urgent" items first.	You have foundations. Close the gaps in your lowest two areas.	Keep evidence current, test your plans and review yearly.

Figure 12 Reading your total (out of 80)

From scores to a risk register

List every statement you scored 0 or 1 in a risk register (Appendix J). For each, write the risk in plain words, rate its **likelihood** and **impact** from 1 to 3, multiply for a score, name an owner and set a date. Do the highest scores first.

HYPOTHETICAL EXAMPLE **Hypothetical case study: five fixes**

The events agency's 29 points mostly came from missing MFA, no inventory, no supplier agreements, no incident log and no staff briefing. She makes a five-line register, gives herself six weeks and tackles them in score order. She repeats the audit after 30 days and scores 52. Nothing she did was complicated.

Common mistakes and misconceptions

Audit myths

Misconception	Reality
"A high score means we are compliant."	It shows where you stand. It is not a legal assessment.
"We should score ourselves generously."	Honest scores are more useful.
"One audit is enough."	Repeat it, and keep dated copies.
"The audit is the improvement."	The fixes are the improvement.

Step by step

1. **Set aside 90 minutes** with the person who knows your systems best.
2. **Score honestly,** and note evidence.
3. **Total each area** and the whole.
4. **Turn 0s and 1s into a risk register.**
5. **Date it, file it and repeat in 30 days and at least yearly.**

CHAPTER 18 CHECKLIST

- [ ] I have scored all eight areas.
- [ ] I know my two weakest areas.
- [ ] I have a risk register of the top ten gaps.
- [ ] I have a date to repeat the audit.
- [ ] The results are filed with a date.

WHAT TO DO TODAY **What to do today**

Score just Area 5, Access control. It takes five minutes and shows where your quickest wins are.

Summary

- The audit covers eight areas, scored 0 to 2 per statement.
- It is a self-assessment, not a legal opinion.
- Convert gaps into a ranked risk register.
- Repeat and keep dated records.

SOURCE NOTE **Key sources**

[16] ENISA, *Cybersecurity guide for SMEs*. [17] NIST, *Cybersecurity Framework* 2.0. [21] European Commission, *Data protection: rules for business and organisations*.

PART V · YOUR PRACTICAL PROTECTION TOOLKIT

CHAPTER

19

Your 30-Day Digital Risk Reduction Plan

Four phases, thirty small tasks, with urgent risks separated from improvements that can wait.

IN THIS CHAPTER

- A day-by-day plan in four phases
- Which tasks are urgent and which can be scheduled
- How long each task takes and what "done" looks like
- A progress tracker and one-page summary

SOURCE NOTE **DATA SHIELD · T Tighten and I Improve**

The plan turns the method into a calendar. Tightening happens in weeks one to three. Improving is week four, and then continuous.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the thirty-day sprint**

A fifteen-person design agency decides to act after a client's security questionnaire exposes several gaps. The owner assigns herself 30 minutes a day and one hour on Fridays. She does not try to fix everything. She starts with what is urgent.

Tasks are tagged **[URGENT]** where a gap exposes you to the most common and most damaging routes, and **[SCHEDULE]** where an improvement can be planned. Times are estimates for a business of five to twenty people. Adjust them to your size.



You cannot protect what you cannot see. This week is about finding out what you have and what could go wrong.

DAY 1

[URGENT] Name an owner

Task: appoint one person responsible for privacy and security decisions. **Why:** decisions need an owner. **Time:** 15 minutes. **Done when:** the name is written down and the team has been told.

☐ DONE

DAY 2

[URGENT] Switch on MFA for email and finance

Task: enable multifactor authentication on email, banking and payment accounts. **Why:** it blocks most password-based takeovers. **Time:** 30 minutes. **Done when:** every such account asks for a second step.

☐ DONE

DAY 3

[URGENT] Find forwarding rules and old access

Task: check email forwarding rules, and list former staff and contractors who still have access. **Why:** hidden access is common. **Time:** 30 minutes. **Done when:** unknown rules are removed and the list is ready for action.

☐ DONE

DAY 4

[URGENT] List your systems and data

Task: write down every system that holds personal or payment data, and who can access it (Chapters 1 and 3). **Why:** you cannot protect what you cannot name. **Time:** 60 minutes. **Done when:** you have a one-page map.

☐ DONE

DAY 5

[URGENT] Ask about AI tools

Task: ask each person which AI tools they use for work, and promise no blame. **Why:** hidden use is the biggest gap. **Time:** 30 minutes. **Done when:** every person has answered.

☐ DONE

DAY 6

[SCHEDULE] List your suppliers

Task: list every service from invoices and card statements, and tier them (Chapter 15). **Why:** supplier risk is your risk. **Time:** 45 minutes. **Done when:** a tiered list exists.

☐ DONE

DAY 7

[SCHEDULE] Take the audit

Task: score the eight areas in Chapter 18. **Why:** a baseline lets you measure progress. **Time:** 90 minutes. **Done when:** a dated score is filed.

☐ DONE



DAYS 8 TO 14

Fix the most important security weaknesses

Now you act on what you found. The focus is the baseline controls from Chapter 14, in order of impact.

DAY 8

[URGENT] Remove old accounts and access

Task: delete accounts for leavers, unused tools and shared logins. **Why:** unused access is a standing risk. **Time:** 45 minutes. **Done when:** the list from Day 3 is empty.

☐ DONE

DAY 9

[URGENT] Install a password manager

Task: choose one, move the most important accounts into it and use unique passwords. **Why:** reused passwords turn one leak into many. **Time:** 60 minutes. **Done when:** email and finance accounts have unique passwords.

☐ DONE

DAY 10

[URGENT] Turn on automatic updates

Task: enable updates on systems, browsers, plug-ins and the router, and change default passwords. **Why:** updates close known holes. **Time:** 45 minutes. **Done when:** no device or router uses defaults or old software.

☐ DONE

DAY 11

[URGENT] Encrypt and lock devices

Task: switch on disk encryption and screen locks on laptops and phones. **Why:** a lost device should not mean lost data. **Time:** 45 minutes. **Done when:** each device is encrypted and locked.

☐ DONE

DAY 12

[URGENT] Test a backup

Task: restore one important file or folder from backup (Chapter 17). **Why:** untested backups often fail. **Time:** 45 minutes. **Done when:** you opened the restored file.

☐ DONE

DAY 13

[SCHEDULE] Review cloud sharing

Task: check sharing links and permissions for sensitive folders. **Why:** open links are quiet leaks. **Time:** 45 minutes. **Done when:** no sensitive item is open to "anyone with the link".

☐ DONE

DAY 14

[URGENT] Adopt the call-back rule

Task: require phone confirmation, on a stored number, for any new or changed bank details (Chapter 8). **Why:** it defeats invoice fraud. **Time:** 20 minutes. **Done when:** everyone who handles payments has agreed.

☐ DONE



DAYS 15 TO 21

Improve GDPR and AI governance

With the worst gaps closed, you turn to documentation and rules, using Parts II and III.

DAY 15

[URGENT] Set your never-paste list

Task: write the information that must never go into AI tools, and name the approved tools (Chapters 5 and 6). **Why:** staff need a rule they can apply in seconds. **Time:** 45 minutes. **Done when:** the list is sent to everyone.

☐ DONE

DAY 16

[SCHEDULE] Check your top AI tool

Task: run the seven-point check from Chapter 7 on the AI tool used most. **Why:** terms differ by plan. **Time:** 60 minutes. **Done when:** each answer has evidence or is marked unknown.

☐ DONE

DAY 17

[SCHEDULE] Build the data inventory

Task: fill in the four columns for your main data (Chapter 10, Appendix D). **Why:** it is the base of everything else. **Time:** 90 minutes. **Done when:** the top ten data uses are recorded.

☐ DONE

DAY 18

[SCHEDULE] Choose lawful bases

Task: record a lawful basis and retention period for each item. **Why:** the law requires a basis for every use. **Time:** 60 minutes. **Done when:** each row is complete.

☐ DONE

DAY 19

[SCHEDULE] Fix your privacy notice and cookies

Task: compare the notice to your inventory and test the cookie banner (Chapter 11). **Why:** transparency must match practice. **Time:** 60 minutes. **Done when:** the notice is accurate and non-essential cookies wait for consent.

☐ DONE

DAY 20

[SCHEDULE] Sign supplier agreements

Task: get DPAs from your top suppliers and note transfer mechanisms (Chapter 12). **Why:** Article 28 requires a contract. **Time:** 90 minutes. **Done when:** top five suppliers are covered or flagged.

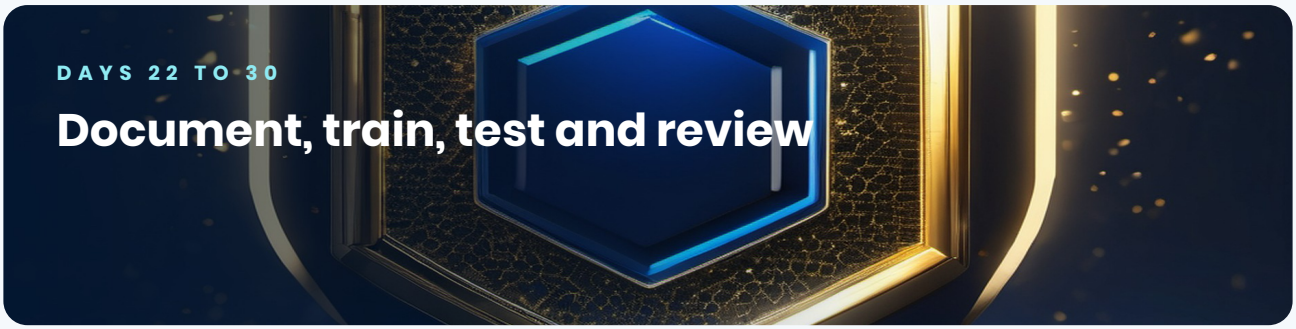
☐ DONE

DAY 21

[SCHEDULE] Screen for DPIAs

Task: run the screening questions on any planned tool or project (Chapter 13). **Why:** high-risk processing needs one. **Time:** 30 minutes. **Done when:** an answer is recorded.

☐ DONE



DAYS 22 TO 30

Document, train, test and review

The last stretch makes the changes stick: a policy, a briefing, a rehearsal and a review.

DAY 22

[URGENT] Write the incident plan

Task: name the incident lead, find the authority's notification page and print the log (Chapter 16). **Why:** you will not think clearly during an incident. **Time:** 45 minutes. **Done when:** the plan is saved where everyone can reach it.

☐ DONE

DAY 23

[SCHEDULE] Write the staff policy

Task: adapt the template in Appendix B and publish it. **Why:** a written rule is a fair rule. **Time:** 60 minutes. **Done when:** every person has read it.

☐ DONE

DAY 24

[SCHEDULE] Brief the team

Task: hold a 45-minute session on phishing, impersonation, the never-paste list and how to report (Chapter 4). **Why:** people are your defence. **Time:** 45 minutes. **Done when:** everyone attended or has watched a recording.

☐ DONE

DAY 25

[SCHEDULE] Rehearse an incident

Task: run a 30-minute tabletop exercise using the Chapter 16 scenario. **Why:** it exposes gaps in a calm setting. **Time:** 30 minutes. **Done when:** the gaps are noted.

☐ DONE

DAY 26

[SCHEDULE] Complete the risk register

Task: list remaining gaps with owner and date (Appendix J). **Why:** it turns concerns into a plan. **Time:** 45 minutes. **Done when:** every gap has an owner and a date.

☐ DONE

DAY 27

[SCHEDULE] Set up offboarding

Task: write a leaving checklist that removes access the same day. **Why:** stale access is risky. **Time:** 30 minutes. **Done when:** the checklist is in use.

☐ DONE

DAY 28

[SCHEDULE] Retake the audit

Task: score the eight areas again. **Why:** progress motivates and proves effort. **Time:** 60 minutes. **Done when:** the new score is filed beside the old.

☐ DONE

DAY 29

[SCHEDULE] File your evidence

Task: put inventory, notice, DPAs, policy, audit, log and risk register in one folder. **Why:** accountability means being able to show your work. **Time:** 30 minutes. **Done when:** the folder exists and is dated.

☐ DONE

DAY 30

[SCHEDULE] Set the review calendar

Task: book a monthly 30-minute review (Appendix K) and an annual full review. **Why:** protection is continuous. **Time:** 15 minutes. **Done when:** the dates are in the diary.

☐ DONE

Progress tracker

DAY 01 ☐	DAY 02 ☐	DAY 03 ☐	DAY 04 ☐	DAY 05 ☐	DAY 06 ☐
DAY 07 ☐	DAY 08 ☐	DAY 09 ☐	DAY 10 ☐	DAY 11 ☐	DAY 12 ☐
DAY 13 ☐	DAY 14 ☐	DAY 15 ☐	DAY 16 ☐	DAY 17 ☐	DAY 18 ☐
DAY 19 ☐	DAY 20 ☐	DAY 21 ☐	DAY 22 ☐	DAY 23 ☐	DAY 24 ☐
DAY 25 ☐	DAY 26 ☐	DAY 27 ☐	DAY 28 ☐	DAY 29 ☐	DAY 30 ☐

HYPOTHETICAL EXAMPLE **Hypothetical case study: day 30**

The design agency finishes day 30 with MFA everywhere, a password manager, a tested backup, an inventory, five signed DPAs, a policy, a briefed team and a rehearsed incident plan. Its score has risen from 31 to 58. Nothing is perfect. Everything is better, and the next client questionnaire takes an hour instead of a week.

Common mistakes and misconceptions

Planning myths

Misconception	Reality
"We must do everything in 30 days."	Do the urgent items first. The rest can follow.
"We have no time."	Thirty small tasks beat one big postponed project.
"Once done, we are finished."	Monthly review keeps it alive.

THE 30-DAY PLAN ON ONE PAGE

- ☐ Days 1 to 7: owner named, MFA on key accounts, forwarding checked, systems listed, AI tools surveyed, suppliers listed, baseline audit done.
- ☐ Days 8 to 14: old access removed, password manager in use, updates and encryption on, backup tested, sharing reviewed, call-back rule agreed.
- ☐ Days 15 to 21: never-paste list set, AI tool checked, inventory built, lawful bases chosen, notice and cookies fixed, supplier DPAs requested, DPIA screening done.
- ☐ Days 22 to 30: incident plan written, policy published, team briefed, incident rehearsed, risk register finished, offboarding set, audit repeated, evidence filed, review dates booked.

WHAT TO DO TODAY **What to do today**

Do Day 1 and Day 2 now: name the owner and switch on MFA for email. Then put the rest in your diary.

Summary

- Four phases, thirty small tasks, urgent items first.
- Schedule the rest, and keep a record.
- Repeat the audit after 30 days.
- Review monthly.

SOURCE NOTE **Key sources**

[16] ENISA, *Cybersecurity guide for SMEs*. [17] NIST, *Cybersecurity Framework* 2.0. Chapters 4 to 17 for the underlying rules.



PART V · YOUR PRACTICAL PROTECTION TOOLKIT

CHAPTER

20

Turning Compliance Into Customer Trust

How responsible AI use, clear privacy practice, proportionate security and documented procedures strengthen confidence.

IN THIS CHAPTER

- Why privacy and security can be a commercial advantage
- What customers and business clients look for
- How to communicate your practices honestly
- Why you should not claim more than you can prove

SOURCE NOTE **DATA SHIELD · D Defend and L Learn**

Defence is a continuing practice. Trust is what customers give you when they see it.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the questionnaire**

A small software consultancy is shortlisted for a contract with a regional retailer. The retailer sends a ten-page supplier questionnaire on security, privacy and AI use. Two competitors take weeks to answer and ask for extensions. The consultancy answers in two days, attaching its policy, its supplier list, its incident plan and its latest audit. It wins the contract. It did not have the biggest security budget. It had records.

Why trust matters commercially

Customers share personal information when they trust you with it. Business clients increasingly ask about security, privacy and AI use before they sign. Being able to answer calmly and with evidence is a competitive strength. The GDPR's accountability principle points the same way: the ability to **demonstrate** what you do (Article 5(2)) is both a legal expectation and a commercial asset [1].

Four things that build confidence

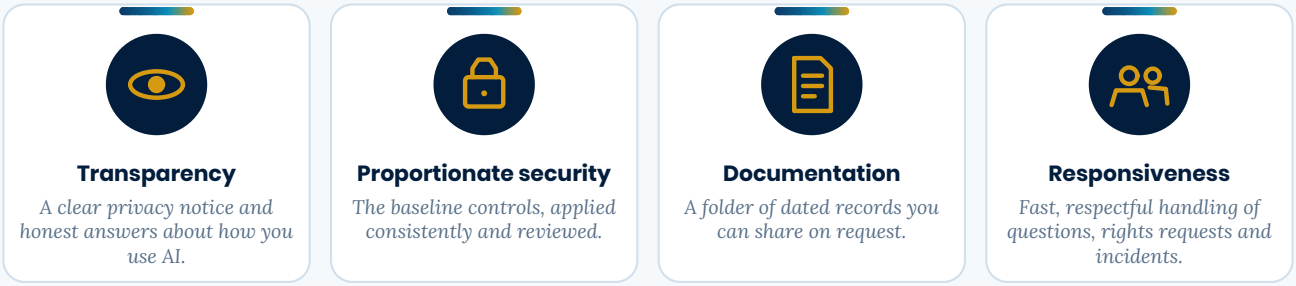


Figure 13 Trust is built from visible habits

Communicating honestly

Say what you do, in plain words, and no more. Avoid phrases such as "fully GDPR compliant", "military-grade security" or "100% safe". Compliance is not a status that any business holds permanently, and no security is absolute. Better statements are factual: "We use multifactor authentication on all staff accounts", "We do not enter customer personal data into AI tools that we have not approved", "We keep backups and test them quarterly", "We review our suppliers each year". If you are certified to a standard such as ISO/IEC 27001, say so, and say which scope [31].

> **WATCH OUT** **Do not overclaim**
>
> Claims that go beyond the facts can mislead customers and can create legal exposure of their own. Never state that using a tool, template or book makes you compliant. Use specific, checkable statements instead.

AI and trust

Customers care about how AI touches their data and decisions. A short AI statement helps: which tools you use, that personal data is not entered into unapproved tools, that people review AI output, and how to ask questions. If you use AI systems that interact with people, or generate synthetic content, the EU AI Act's transparency duties in Article 50 may apply to you, with application dates that were adjusted by the 2026 amendment, so check the current position [2][3]. The AI Act's AI-literacy duty, in Article 4, asks providers and deployers to take measures to ensure staff have a sufficient level of AI literacy, and the amended wording should be checked [2][3].

HYPOTHETICAL EXAMPLE **Hypothetical case study: the one-page trust statement**

A small online clinic publishes a one-page "How we protect your information" page. It lists its security basics, its approach to AI, its retention rules and how to ask questions, and it names a contact. Enquiries mention it. Staff use it as the basis for answering client questionnaires. It is not a marketing claim. It is a description of what the clinic actually does and can evidence.

Answering a customer or client questionnaire

Business clients increasingly send security and privacy questionnaires. Treat them as an opportunity. Answer honestly, and attach evidence instead of adjectives. A prepared folder makes it routine: your privacy notice, your security summary, your supplier list and DPAs, your incident plan, your AI policy, and the dated results of your latest audit. If you cannot do something yet, say so and give the date by which you will. Clients often value honesty about a gap more than a perfect-sounding answer that later proves untrue. Never answer "yes" to a question you cannot back up.

Common mistakes and misconceptions

Trust myths

Misconception	Reality
"Compliance is a badge."	It is an ongoing practice.
"Customers do not care."	Many ask, especially business clients.
"Marketing claims are harmless."	Overclaims can mislead and create liability.
"Trust is built by a big announcement."	It is built by consistent habits.

Step by step

1. **List five facts you can prove** about your security and privacy practice.
2. **Write them in plain words,** with no superlatives.
3. **Add how you use AI** and what you do not do with it.
4. **Name a contact** and a response time.
5. **Review it twice a year,** and whenever practice changes.

CHAPTER 20 CHECKLIST

- [ ] I have a short, factual trust statement.
- [ ] I can answer a client questionnaire from my records.

- [ ] I avoid claims such as "fully compliant" or "100% secure".
- [ ] My AI statement matches my policy.
- [ ] I review the statement regularly.

WHAT TO DO TODAY **What to do today**

Write five true, checkable sentences about how you protect customer information. Those are the start of your trust page.

Summary

- Visible, documented habits build trust.
- Be specific and honest. Never overclaim.
- Evidence turns questionnaires into routine work.
- Defence is ongoing.

SOURCE NOTE **Key sources**

[1] GDPR, Article 5(2). [2] AI Act, Articles 4 and 50. [3] Regulation (EU) 2026/1744 (reported). [31] ISO/IEC 27001.

CONCLUSION

CONCLUSION

DS

You Are Not Too Small to Matter, and Not Too Small to Protect

Calm, proportionate protection is within reach of every small business.

IN THIS CHAPTER

- The DATA SHIELD METHOD in one page
- Five steps for this week
- What this book could not do for you

At the start of this book, Nika clicked a link, an assistant pasted a customer list and a bookkeeper changed a bank account. None of it needed a master criminal. All of it could have been prevented, or limited, by ordinary habits: a second step at login, a rule about what goes into AI tools, a phone call before a payment.

The point of this book has not been to frighten you. Your data is valuable. Criminals want it, AI tools can expose it, careless moments can leak it and weak privacy practice can turn a small mistake into a business crisis. But **small businesses are not helpless**. A short list of well-chosen habits, repeated, protects a great deal.

The DATA SHIELD METHOD, one last time



Figure 14 · Ten steps in five pairs

The method is an original framework created for this book. It is not an official standard. Its value is that it gives you an order: see, judge, fix, record, protect, prepare, improve, prove, learn and keep going.

Five steps for this week

1. **Turn on multifactor authentication** for email, banking and cloud storage.
2. **Write your never-paste list** for AI tools and name the approved ones.
3. **Agree the call-back rule** for payments and bank-detail changes.
4. **List your data and your suppliers** in one spreadsheet, with a lawful basis and a retention period.
5. **Name your incident lead** and save your supervisory authority's breach page.

What this book cannot do

It cannot make you compliant, because compliance is an ongoing practice that depends on your facts. It cannot make you immune to attack. It cannot replace a lawyer when you face a hard legal question or a specialist when you face a serious incident. It does not take your national law into account. And it will age: the law, the guidance and the tools will change. Use the sources in Appendix M to keep current.

Where to go next

Use this book and its templates as starting points that you adapt to your own business. Your national supervisory authority, for example Croatia's AZOP at https://azop.hr/, and the EDPB at https://www.edpb.europa.eu/ remain the primary guides to how the law is applied.

THE LAST WORD

Protection is not one big project. It is a set of small habits, repeated. Start today, keep going and keep it honest.

Your Final Practical Checklist

Twenty statements to review today, and again every quarter.

TWENTY STATEMENTS TO KEEP TRUE

- [ ] MFA is on for email, banking, payment and cloud accounts.
- [ ] Everyone uses a password manager and unique passwords.
- [ ] Software, devices and routers update automatically.
- [ ] Laptops and phones are encrypted and locked.
- [ ] Backups are tested, and one copy is offline or immutable.
- [ ] Access is least-privilege and leavers lose it on their last day.
- [ ] There is a data inventory with purposes, lawful bases and retention periods.
- [ ] The privacy notice matches what we really do.
- [ ] Non-essential cookies wait for consent, and rejecting is as easy as accepting.
- [ ] Rights requests are logged and answered within one month.
- [ ] Every supplier that handles personal data has a DPA and a recorded transfer mechanism.
- [ ] Suppliers are reviewed at least once a year.
- [ ] A never-paste list exists, and AI tools are approved by name.
- [ ] A person checks AI output before it is used.
- [ ] Payment and bank-detail changes need a call-back.

- [ ] Staff have had training this year and know how to report.
- [ ] An incident lead, an incident log and the authority's notification page are ready.
- [ ] Every personal data breach is documented, whether or not it is notified.
- [ ] The risk register is current and reviewed monthly.
- [ ] This checklist was reviewed in the last three months.

GOOD PRACTICE **Keep it alive**

Print this page, date it and keep it in your evidence folder. Review it every quarter. A dated record of review is itself a piece of accountability.

SOURCE NOTE **How to use the appendices**

Every template here is a **starting point that must be adapted** to your organisation's circumstances, national law and risks. Replace the text in [square brackets], delete what does not apply, date it, and have significant documents reviewed by a qualified adviser. A template is not legal advice and does not make you compliant. The editable PDF edition lets you type into the forms.

Small Business GDPR Checklist

A starting point. Adapt it to your organisation.

SMALL BUSINESS GDPR CHECKLIST (TICK WHAT IS TRUE TODAY)

- [ ] I have decided whether I am a controller, a processor or both for each activity.
- [ ] I have a data inventory or record of processing, even though the Article 30(5) exception is rarely available.
- [ ] Every use of personal data has a recorded lawful basis (Article 6).
- [ ] Special-category data has an additional Article 9 condition and extra protection.
- [ ] Data collection is limited to what is necessary (minimisation).
- [ ] Retention periods are set, and data past them is deleted.
- [ ] My privacy notice covers the Article 13 and 14 information and is easy to find.
- [ ] Cookies and trackers follow ePrivacy rules and national law, with consent where required.
- [ ] I can handle access, correction, erasure, objection and portability requests within one month.
- [ ] Every processor has an Article 28 contract.

- [ ] Sub-processors and international transfers are recorded, with a valid transfer mechanism.
- [ ] Security measures are appropriate to the risk and documented (Article 32).
- [ ] New projects and tools are screened for data protection impact assessment need.
- [ ] I know whether a DPO is required and have recorded the decision.
- [ ] There is a breach procedure, a log, and the authority's notification route.
- [ ] Staff are trained, and AI use is governed by a written policy.
- [ ] Records are dated, stored together and reviewed at least yearly.

Responsible AI Use Policy Template

A starting point. Adapt it, date it, and have it checked by an adviser.

[Organisation name] Responsible AI Use Policy. Version [1.0]. Date [date]. Owner [name and role]. Review date [date].

1. Purpose

This policy explains how people at [organisation] may use artificial intelligence (AI) tools in their work, so that we protect personal data, confidential information and our customers' trust, and meet our legal duties.

2. Who it applies to

Employees, contractors, interns and anyone else who uses [organisation]'s systems or information.

3. Approved tools

Only AI tools on the approved list may be used for work. The list is maintained by [owner] and shows each tool, plan, permitted purposes and review date. Personal or free accounts must not be used for work involving personal data or confidential information. To request a new tool, contact [owner] before using it.

4. Information levels

- **Public:** may be used in approved tools.
- **Internal:** approved tools only, and only what the task needs.
- **Confidential:** approved tools only, minimised, and only where the contract and the tool's terms allow it. Ask first if unsure.
- **Personal or sensitive:** only where there is a lawful basis, people have been informed and the tool is approved for that purpose. Never enter special-category data, children's data, identity documents, payment card details, passwords, keys or tokens unless [owner] has approved it in writing.

5. Good practice

- Describe the situation, not the person. Use placeholders for names and identifiers.
- Do not upload files without checking for hidden sheets, comments and metadata.
- Do not connect AI tools to email, drives or systems without approval.
- Do not rely on AI output as fact. A person must check it before it is sent, published or used to decide something about a person.
- Do not use AI to make decisions about individuals that have legal or similarly significant effects without a documented review by [owner].
- Do not present AI-generated content as human-made where we are required to say it is not.

6. Reporting

If you think something has been entered that should not have been, tell [owner] immediately on [contact]. You will not be blamed for an honest, prompt report.

7. Monitoring and review

[Owner] reviews this policy and the approved tools list at least every [six] months, and when laws, tools or terms change.

8. Acknowledgement

I have read and understood this policy. Name [ ] Date [ ] Signature [ ]

WATCH OUT **Adapt before use**

Employment, monitoring and works-council rules vary by country. If you monitor staff use of AI tools, tell staff clearly and check national law first.

AI Tool Approval Checklist

A starting point. Complete one per tool and keep the evidence.

AI TOOL APPROVAL

Area	Question	Answer	Evidence and date
1. Tool	Tool, provider, plan and account type		
2. Purpose	Business purpose and who will use it		
3. Data	Data levels it will handle (public, internal, confidential, personal)		

Area	Question	Answer	Evidence and date
4. Role and DPA	Is the provider a processor for this use? Is a DPA included?		
5. Training	Is content used to train models? On which plan and by what setting?		
6. Retention	Retention, deletion and who controls it		
7. Sub-processors	Sub-processors and data locations		
8. Transfers	Transfer mechanism, if data leaves the EEA		
9. Security	MFA, single sign-on, admin controls, certifications		
10. Connections	What can it read or change?		
11. DPIA	DPIA screening result		
12. Decision	Approve, approve with conditions or reject; owner; review date		

Data Inventory and Record of Processing Starter

A starting point. Article 30 lists the content of a full record.

A record of processing should capture, for controllers: purposes; categories of individuals and data; recipients; transfers to third countries; retention time limits where possible; and a general description of security measures (Article 30(1)) [1]. Processors keep a record of the processing they carry out for each controller (Article 30(2)).

DATA INVENTORY AND RECORD OF PROCESSING

Activity	Purpose	Data and individuals	Lawful basis	Recipients and transfers	Retention	Security
e.g. Order fulfilment	*e.g. Deliver purchases*	*e.g. Customer names, addresses*	*e.g. Contract (6(1)(b))*	*e.g. Courier; shop platform*	*e.g. 6 years if required by tax law*	*e.g. Access limited to two staff; MFA*

Activity	Purpose	Data and individuals	Lawful basis	Recipients and transfers	Retention	Security
e.g. Newsletter	*e.g. Marketing*	*e.g. Subscribers' emails*	*e.g. Consent (6(1)(a))*	*e.g. Email provider (processor)*	*e.g. Until withdrawal*	*e.g. Provider security; DPA*

Vendor and AI Supplier Assessment Questionnaire

A starting point. Send it to a supplier or complete it from public documents.

SUPPLIER QUESTIONNAIRE

Area	Question	Supplier answer	Evidence and date
1. Company	Legal entity, country of establishment, contact for privacy		
2. Service	Exact product, plan and features in scope		
3. Roles	Are you our processor? For which purposes are you an independent controller?		
4. DPA	Do you provide a DPA covering Article 28(3)?		
5. Data	What categories of personal data are processed?		
6. Training	Is customer content used to train or improve models? Can it be switched off?		

Area	Question	Supplier answer	Evidence and date
7. Retention	How long is data kept? How do we delete it?		
8. Sub-processors	Where is the list, and how will changes be notified?		
9. Location	Where is data stored and accessed from?		
10. Transfers	What transfer mechanism applies? Is the DPF certification current if relied on?		
11. Security	Which controls and certifications apply (encryption, MFA, logging)?		
12. Access	Which of your staff can access our data, and under what conditions?		
13. Incidents	How and how fast will you tell us about a breach?		
14. Rights	How will you help us respond to individuals' requests?		
15. Audit	What information and audit rights do we have?		
16. Exit	How can we export our data, and is it deleted at the end?		
17. AI features	Are AI features optional? What data do they use?		

Data Breach Incident Log

A starting point. Keep one row per incident, and keep the original.

INCIDENT LOG (ARTICLE 33(5) DOCUMENTATION)

Ref and date aware	What happened	Data and people affected	Risk assessment	Notified authority? (date)	Informed individuals?	Actions and lessons
e.g. 001, 12 Mar 09:15	*e.g. Email sent to wrong recipient*	*e.g. 12 customers' names and orders*	*e.g. Low risk, recipient confirmed deletion*	*e.g. No: unlikely to result in a risk, reasons recorded*	*e.g. No*	*e.g. Added a pause step; training reminder*

Personal Data Breach Response Checklist

A starting point. Print it and keep it with your incident plan.

IN THE FIRST HOUR

- ☐ Write down the time you became aware and who told you.
- ☐ Tell the incident lead and start the log.
- ☐ Contain: disconnect affected devices, stop the mistake, but do not wipe evidence.
- ☐ Secure accounts: change passwords, revoke sessions, enable MFA, remove strange rules.
- ☐ Preserve screenshots, logs and copies of messages.

IN THE FIRST DAY

- [ ] Establish which systems and which data were affected, and whose.
- [ ] Check whether personal data is involved, and what kind.
- [ ] Contact your adviser, IT help and insurer if the policy requires it.
- [ ] Check contracts for client notification duties.

BY 72 HOURS OF BECOMING AWARE

- [ ] Assess the risk to individuals: type of data, ease of identification, severity, number of people.
- [ ] Record whether a risk is unlikely, and why.
- [ ] If a risk is not unlikely, notify the supervisory authority, in phases if needed, with reasons for any delay.
- [ ] If a high risk is likely, tell affected individuals in clear language (Article 34).
- [ ] Record every decision and the reasons.

AFTERWARDS

- [ ] Fix the cause and restore from clean backups.
- [ ] Review what worked and what did not.
- [ ] Update the plan, the training and the risk register.
- [ ] File the log with the evidence.

Employee Security Awareness Checklist

A starting point. Use it in onboarding and yearly refreshers.

EMPLOYEE SECURITY AWARENESS CHECKLIST

- [ ] I use a password manager and a unique password for each account.
- [ ] I have multifactor authentication on my work accounts.
- [ ] I lock my screen when I leave my desk, and my devices are encrypted.
- [ ] I know how to spot phishing and I do not log in from links in messages.
- [ ] I confirm payment and bank-detail changes by phone, using a number we already hold.

- [ ] I never paste passwords, special-category data, ID documents or confidential contracts into AI tools.
- [ ] I only use AI tools that the company has approved.
- [ ] I check AI output before I send or publish it.
- [ ] I use only approved cloud storage and I check sharing settings.
- [ ] I keep work and personal accounts separate.
- [ ] I report suspicious messages and mistakes immediately, and I know to whom.
- [ ] I know that I will not be blamed for an honest, prompt report.

Data Retention Schedule Template

A starting point. National law may set minimum or maximum periods.

RETENTION SCHEDULE

Record type	Why we keep it	Basis (law, contract, need)	Retention period	Review and deletion method	Owner
e.g. Customer orders	*e.g. Delivery, accounting*	*e.g. Contract; tax law*	*e.g. [check national law]*	*e.g. Annual review; deleted in shop platform*	*e.g. Owner*
e.g. Job applications	*e.g. Recruitment*	*e.g. Legitimate interests*	*e.g. [set, with a reason]*	*e.g. Deleted from mail and folders*	*e.g. HR lead*

Privacy and Security Risk Register

A starting point. Score likelihood and impact from 1 (low) to 3 (high).

RISK REGISTER

Risk	Likelihood (1-3)	Impact (1-3)	Score	Control	Owner	Due date
e.g. Staff paste customer data into unapproved AI tools	*e.g. 3*	*e.g. 3*	*e.g. 9*	*e.g. Approved tool; never-paste list; training*	*e.g. Owner*	*e.g. 15 Nov*
e.g. Email account taken over	*e.g. 2*	*e.g. 3*	*e.g. 6*	*e.g. MFA; password manager*	*e.g. Office manager*	*e.g. 30 Nov*

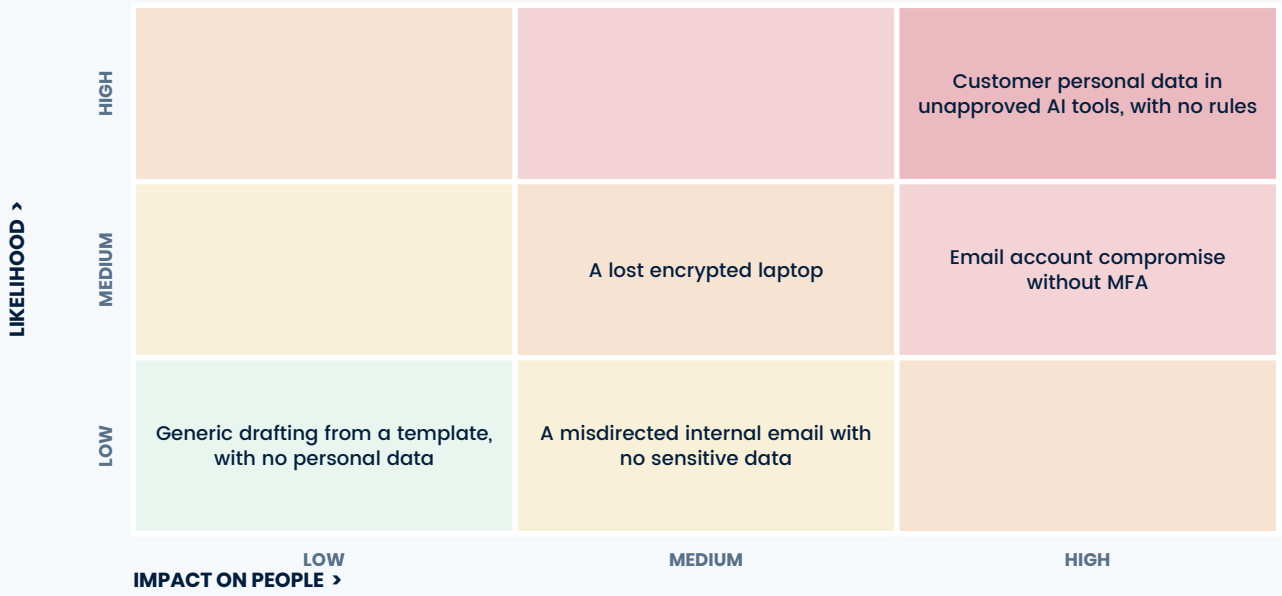


Figure 15 Rough risk matrix (likelihood 1 to 3, impact 1 to 3)

Monthly Security Review Checklist

A starting point. Thirty minutes, once a month.

MONTHLY REVIEW

- [ ] Check for new accounts, tools, extensions or AI services that nobody approved.
- [ ] Remove access for anyone who has left or changed role.
- [ ] Confirm updates are installed on devices, routers and plug-ins.
- [ ] Review the incident and near-miss log, and any rights requests.
- [ ] Check that one backup can be restored.
- [ ] Check cloud sharing links for sensitive files.
- [ ] Review supplier changes: new sub-processors, terms or incidents.
- [ ] Check for relevant changes in law or guidance (see Appendix M).
- [ ] Update the risk register and note one improvement for next month.
- [ ] Date and file this checklist.

Glossary of Terms

Plain-English definitions. They are explanations, not legal definitions.

Accountability	The duty to be able to demonstrate how you comply with data protection principles (Art. 5(2))
Adequacy decision	A Commission decision that a non-EEA country or framework gives essentially equivalent protection (Art. 45)
AI literacy	A sufficient understanding of AI among people who use or operate it (AI Act, Art. 4)
Anonymisation	Making information so that a person can no longer be identified by any means reasonably likely to be used
Attack surface	All the places where an attacker could try to get in, or data could leak out
Backup	A copy of data kept so it can be restored after loss
Controller	The party that decides why and how personal data is processed (Art. 4(7))
Cookie	A small file stored on a device, often to remember a visitor or track activity
Data minimisation	Collecting only the data you need
Data subject	The person that personal data is about
Deepfake	Audio, image or video altered or generated by AI to look or sound like something real
DPA	A data processing agreement between a controller and a processor (Art. 28)
DPIA	A data protection impact assessment of high-risk processing (Art. 35)
DPO	A data protection officer, who advises on and monitors compliance (Arts 37 to 39)
EDPB	European Data Protection Board, which issues guidance on the GDPR
EEA	European Economic Area: the EU plus Iceland, Liechtenstein and Norway
ENISA	European Union Agency for Cybersecurity
Encryption	Scrambling data so only those with the key can read it
GDPR	General Data Protection Regulation, Regulation (EU) 2016/679
Least privilege	Giving people the minimum access needed for their job

Lawful basis	The legal ground that allows processing (Art. 6)
MFA	Multifactor authentication: proving identity with more than one factor
NIS2	Directive (EU) 2022/2555 on network and information security, for certain sectors and sizes
NIST CSF	The US National Institute of Standards and Technology Cybersecurity Framework, a voluntary framework
Patching	Installing updates that fix security flaws
Personal data	Any information about an identified or identifiable person (Art. 4(1))
Personal data breach	A security breach leading to destruction, loss, alteration, unauthorised disclosure of or access to personal data (Art. 4(12))
Phishing	A deceptive message designed to trick someone into acting, such as entering a password
Processing	Any operation on personal data
Processor	A party that processes personal data on behalf of a controller (Art. 4(8))
Prompt	The text or files you give an AI tool
Pseudonymisation	Replacing identifiers with codes while a key exists; the data is still personal data
RoPA	Record of processing activities (Art. 30)
SCCs	Standard contractual clauses for transfers outside the EEA (Decision (EU) 2021/914)
Special-category data	Sensitive data listed in Art. 9, such as health, ethnicity, religion, biometrics
Sub-processor	A processor engaged by another processor
Supervisory authority	The national regulator for data protection, such as AZOP in Croatia
Third country	A country outside the EEA

Official Sources and Further Reading

Where to check the law, the guidance and the standards. Verify current versions.

Where to look

Type	Source	Link
Binding legislation	EUR-Lex: GDPR (Regulation (EU) 2016/679)	https://eur-lex.europa.eu/eli/reg/2016/679/oj
Binding legislation	EUR-Lex: AI Act (Regulation (EU) 2024/1689), and the 2026 amending regulation	https://eur-lex.europa.eu/eli/reg/2024/1689/oj
Binding legislation	EUR-Lex: ePrivacy Directive 2002/58/EC	https://eur-lex.europa.eu/eli/dir/2002/58/oj
Binding legislation	EUR-Lex: NIS2 Directive (EU) 2022/2555	https://eur-lex.europa.eu/eli/dir/2022/2555/oj
Regulatory guidance	European Data Protection Board: guidelines and opinions	https://www.edpb.europa.eu/
Regulatory guidance	European Commission: data protection for business	https://commission.europa.eu/law/law-topic/data-protection/rules-business-and-organisations_en
Regulatory guidance	National authority, for example Croatia's AZOP	https://azop.hr/
Regulatory guidance	European Commission: AI Act resources	https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai
Cybersecurity guidance	ENISA, including the cybersecurity guide for SMEs	https://www.enisa.europa.eu/
Voluntary frameworks	NIST Cybersecurity Framework	https://www.nist.gov/cyberframework
Voluntary standards	ISO/IEC 27001 (information security management)	https://www.iso.org/

Sources

Numbered sources used in the text. Legal research cut-off: 24 October 2026.

SOURCE NOTE **How to read these sources**

Binding law is cited by instrument. **Regulatory guidance** (EDPB, Commission, ENISA, national authorities) is not itself binding law. **Voluntary standards and frameworks** are good practice. The last column says how each source was checked for this edition. **Fetched** means a page was opened and read on 24 October 2026. **Mirror** means the article text was read on an unofficial GDPR text site and not on EUR-Lex. **Secondary** means the primary text could not be read and the point was taken from at least two commentaries. **Working knowledge** means stable text that was not re-read in full for this edition. Anything marked Secondary or Working knowledge should be verified before publication or reliance.

Sources

No.	Source	Where to find it	Type and check
[1]	Regulation (EU) 2016/679 (General Data Protection Regulation), cited by article	https://eur-lex.europa.eu/eli/reg/2016/679/oj	Binding law. Articles 30(5), 33, 37 and 83 read on a mirror (gdpr-info.eu); others working knowledge
[2]	Regulation (EU) 2024/1689 (Artificial Intelligence Act), Articles 4 and 50	https://eur-lex.europa.eu/eli/reg/2024/1689/oj	Binding law. Working knowledge
[3]	Regulation (EU) 2026/1744 amending the AI Act ("AI Omnibus"), reported as published in the Official Journal on 24 July 2026 and in force from 27 July 2026, moving Annex III high-risk obligations to 2 December 2027 and Annex I to 2 August 2028, with adjusted timing for some Article 50 duties. Separately, the Commission's "Digital Omnibus" proposals on the GDPR and ePrivacy had, at the cut-off, not been adopted	Search EUR-Lex for "Regulation (EU) 2026/1744"; European Parliament Legislative Observatory (file 2025/0360(COD))	Binding law and proposals. Secondary: law-firm commentary only. Verify
[4]	Directive 2002/58/EC (ePrivacy Directive), Article 5(3), as implemented in national law	https://eur-lex.europa.eu/eli/dir/2002/58/oj	Binding law. Working knowledge
[5]	Directive (EU) 2022/2555 (NIS2)	https://eur-lex.europa.eu/eli/dir/2022/2555/oj	Binding law. Working knowledge; scope depends on national transposition
[6]	EDPB, Guidelines 07/2020 on the concepts of controller and processor in the GDPR	https://www.edpb.europa.eu/ (Our work and tools, Guidelines)	Regulatory guidance. Working knowledge
[7]	EDPB, Guidelines 9/2022 on personal data breach notification under GDPR, version 2.0, adopted 4 April 2023	https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-92022-personal-data-breach-notification-under_en	Regulatory guidance. Fetched (listing page); content working knowledge
[8]	EDPB, Guidelines 05/2020 on consent under Regulation 2016/679	https://www.edpb.europa.eu/ (Guidelines)	Regulatory guidance. Working knowledge

No.	Source	Where to find it	Type and check
[9]	Article 29 Working Party, Guidelines on Data Protection Impact Assessment (WP248 rev.01), endorsed by the EDPB	https://ec.europa.eu/newsroom/article29/items/611236	Regulatory guidance. Working knowledge
[10]	EDPB, Guidelines 4/2019 on Article 25 data protection by design and by default	https://www.edpb.europa.eu/ (Guidelines)	Regulatory guidance. Working knowledge
[11]	Commission Implementing Decision (EU) 2021/914 on standard contractual clauses	https://eur-lex.europa.eu/eli/dec_impl/2021/914/oj	Binding law. Working knowledge
[12]	Commission Implementing Decision (EU) 2023/1795 (EU-US Data Privacy Framework); General Court, Case T-553/23, Latombe v Commission (3 September 2025); appeal Case C-703/25 P reported as pending	https://eur-lex.europa.eu/eli/dec_impl/2023/1795/oj and https://curia.europa.eu	Binding law and case law. Appeal status secondary (law-firm commentary, mid-2026). Verify
[13]	EDPB, Recommendations 01/2020 on supplementary measures for transfer tools; CJEU Case C-311/18 (Schrems II)	https://www.edpb.europa.eu/ and https://curia.europa.eu	Guidance and case law. Working knowledge
[14]	EDPB, Guidelines 01/2022 on data subject rights: right of access	https://www.edpb.europa.eu/ (Guidelines)	Regulatory guidance. Working knowledge
[15]	EDPB, Opinion 28/2024 on certain data protection aspects of the processing of personal data in the context of AI models	https://www.edpb.europa.eu/ (Opinions)	Regulatory guidance. Working knowledge
[16]	ENISA, Cybersecurity guide for SMEs: 12 steps to securing your business, with the report "Cybersecurity for SMEs: challenges and recommendations" (June 2021)	https://www.enisa.europa.eu/ (publications)	Voluntary guidance. Existence confirmed by search; content working knowledge
[17]	NIST, Cybersecurity Framework (CSF) 2.0	https://www.nist.gov/cyberframework	Voluntary framework. Fetched 24 October 2026 (confirms CSF 2.0 is current)

No.	Source	Where to find it	Type and check
[18]	NIST Special Publication 800-63 series, Digital Identity Guidelines (authentication guidance)	https://pages.nist.gov/800-63-4/	Voluntary standard. Working knowledge; check the current revision
[19]	Agencija za zaštitu osobnih podataka (AZOP), Croatia; page on reporting personal data breaches	https://azop.hr/ and https://azop.hr/izvjescivanje-o-povredi-osobnih-podataka/	National authority. Fetched (link names; form contents not confirmed)
[20]	EDPB, list of national supervisory authorities	https://www.edpb.europa.eu/about-edpb/about-edpb/members_en	Regulatory resource. Working knowledge
[21]	European Commission, Data protection: rules for business and organisations	https://commission.europa.eu/law/law-topic/data-protection/rules-business-and-organisations_en	Regulatory guidance. Working knowledge
[22]	OWASP, Top 10 for Large Language Model Applications	https://genai.owasp.org/	Voluntary guidance. Working knowledge
[23]	ENISA Threat Landscape reports and Europol publications on criminal use of AI (general reading; no figures quoted)	https://www.enisa.europa.eu/ and https://www.europol.europa.eu/	Agency reports. Working knowledge; specific documents not re-read. Verify before quoting
[24]	Directive (EU) 2016/943 on the protection of trade secrets	https://eur-lex.europa.eu/eli/dir/2016/943/oj	Binding law. Working knowledge
[25]	CJEU, Case C-300/21, UI v Österreichische Post (4 May 2023): no minimum seriousness threshold for non-material damage under Article 82	https://curia.europa.eu	Case law. Working knowledge. Verify
[26]	CJEU, Case C-634/21, SCHUFA Holding (7 December 2023), on automated scoring and Article 22	https://curia.europa.eu	Case law. Working knowledge. Verify
[27]	CJEU, Case C-413/23 P, EDPS v SRB (4 September 2025), on pseudonymised data and identifiability	https://curia.europa.eu	Case law. Working knowledge. Verify

No.	Source	Where to find it	Type and check
[28]	CJEU, Case C-673/17, Planet49 (1 October 2019), on pre-ticked cookie consent boxes	https://curia.europa.eu	Case law. Working knowledge
[29]	EDPB, Guidelines 2/2023 on technical scope of Article 5(3) of the ePrivacy Directive	https://www.edpb.europa.eu/ (Guidelines)	Regulatory guidance. Working knowledge; check adopted version
[30]	EDPB, Guidelines 01/2021 on examples regarding personal data breach notification	https://www.edpb.europa.eu/ (Guidelines)	Regulatory guidance. Working knowledge
[31]	ISO/IEC 27001, information security management systems	https://www.iso.org/	Voluntary standard. Working knowledge

About the Author

Zirlandia Milkovic.

Zirlandia Milkovic writes practical guides that help small businesses understand data protection, cybersecurity and responsible AI use, and turn them into everyday habits. She created *Your Data Is the Target* to make these subjects more understandable and actionable for the owners, freelancers and small teams who have to manage them without a legal or security department.

This book is educational and is not legal advice. For decisions with real consequences, consult a qualified professional.



Protect your business.
Build trust.
Stay ahead.

ZIRLANDIA MILKOVIC